고가용성 가상 암호화폐 거래소

한국폴리텍대학 광명융합기술교육원 데이터분석과 파이널 프로젝트 계획서. 1 인 프로젝트. 작성 2026-08-25, 최종 발표 2026-10-16. 모든 수치는 HEAD(2a71234) 기준 실계측값이고, 재현되지 않은 값은 "미확인"으로 표기했다.

요약

무엇을 만드는가. 봇 플릿이 실시간 매매하는 완전 시뮬레이션 암호화폐 거래소. 실거래·실자산 없음. 장애를 의도적으로 주입하고, 원인이 어느 계층인지 좁히고, 장애가 지나간 뒤 데이터가 맞는지를 원장 SQL 로 판정한다.

왜 거래소인가. 복식부기 원장이 정답 상태를 도메인 성질로 이미 갖는다. 자산별 원장 합 0 은 내가 정한 규칙이 아니라 회계 성립 조건이라, 위반이 나오면 변명의 여지가 없다. 게시판이나 부하테스트 대상 서비스로는 사후 정합성 판정이 원리상 불가능하다.

무엇을 증명하는가. 반증 조건이 붙은 두 명제다. ① 체결 무결: 폭주·장애에도 자산별 원장 합 0, 주문 중복·유실 0. ② 자동 복구: 무개입 승격, RTO 30 초 이내, epoch 정확히 +1. 판정 주체는 사람 눈이 아니라 SQL 위반 행 수, 메트릭 임계, 스크립트 exit code 다.

현재 상태. 커밋 220 건, 서버 Java 245 파일, 웹 150 파일, REST 81, 불변식 26 개 상시 검증.

성립	미성립. 남은 6 주의 작업 대상
정합성 판정. 불변식 26 개, 반증 테스트 8 건	계층 판정. 프로브 0 건, tcpdump 미사용
자동 복구. 라이브 PASS 5 건, fencing epoch	데이터 이중화. PostgreSQL 단일 인스턴스
카오스 실험 9 종, 알람 11·대시보드 4	외부 공개, 인프라 보안, 배포 자동화

남은 6 주. 새 기능을 붙이지 않고 전부 인프라·배포·운영·보안에 쓴다. 주입할 대상과 판정할 술어가 둘 다 준비돼 있어 그 위에서 장애를 재현하는 편이 한계효용이 크다.

배포 설계의 핵심 판단. 학교 필수 조건인 외부 상시 접속과 커널 장애 주입은 한 평면에서 양립하지 않는다. 상시면(24 시간)과 증명면(실험 창에만 구동 후 파기)으로 분리하고, 관리형 DB 는 채택하지 않는다. 주입 권한이 없으면 증명이 성립 범위 밖으로 나간다.

비용·일정·완료 기준. 6 주 총계 139,854 원(월 환산 92,425 원)으로 자체 상한 100,000 원 안. 단가는 AWS 공식 요금표 판본 기준이다. 전체 53 일 중 순 가용 336 시간, 계획 186 시간에 예비 60 시간을 남긴다. 고정점은 09-01 제출, 09-08 외부 접속 성립, 10-09 기능 동결, 10-16 발표. 완료 기준은 전부 기계 판정이고 육안 판정 항목은 0 개다.

목차

고가용성 가상 암호화폐 거래소 1

요약 1

목차 2

1. 프로젝트 개요 3

2. 문제 정의와 주제 선정 근거 4

3. 현재 진척과 남은 범위 7

4. 기술 스택과 선택 사유 10

5. 시스템 아키텍처 15

6. 인프라와 배포 설계 17

7. 운영 설계 29

8. 보안 설계 32

9. 비용 산정 37

10. 검증 계획 44

11. 일정 48

12. 완료 기준 55

13. 한계와 리스크 57

1. 프로젝트 개요

1.1 한 줄 정의

봇 플릿이 실시간으로 매매하는 완전 시뮬레이션 암호화폐 거래소. 실거래·실자산·런타임 외부 API 의존이 없다. 이 시스템에 장애를 의도적으로 주입하고, 원인이 어느 계층인지 계층별 근거로 좁히고, 장애가 지나간 뒤 데이터가 맞는지를 원장 SQL 로 판정한다.

1.2 증명하려는 두 명제

기능 목록이 아니라 명제를 증명한다. 명제는 반증 조건을 함께 적을 때만 명제다.

구분	증명 ① 체결 무결	증명 ② 자동 복구
주장	트래픽 폭주와 인프라 장애 아래에서도 자산별 원장 합이 0 이고 주문 중복 접수·중복 체결·주문 유실이 0 이다	리더 노드를 죽여도 사람 개입 없이 승격·복구가 일어나고 체결이 재개된다
관측 대상	ledger_entries, balances, command_journal, event_journal, trades	leader_lease.epoch, command_journal.fencing_token, trades.engine_ts
판정 술어	불변식 26 개의 위반 행 수	승격 후 최초 신규 TRADE 의 engine_ts 에서 kill 시각을 뺀 값(T5 정의는 명령 축 fencing 기준)
PASS 기준	전 항목 0 행	RTO 30 초 이내, epoch 정확히 +1, 수동 개입 0 회
반증 조건	어느 한 술어라도 1 행 반환	30 초 초과, 승격 미발생, 또는 사람이 손대야 재개

1.3 판정 방식

판정 주체는 사람 눈이 아니다. 다음 세 가지로만 판정한다.

판정 수단	구현
SQL 위반 행 수	불변식 검증기가 REPEATABLE READ READ ONLY

	트랜잭션에서 26 개 체크를 돌리고 결과를 invariant_checks 테이블에 적재
메트릭 임계	Prometheus 레코딩 룰 9 개·알람 11 개, Grafana 대시보드 4 종
스크립트 exit code	카오스 오케스트레이터 9 종이 verdict 를 산출하고 종료 코드로 판정

데모 화면이 잘 도는 것은 증거로 치지 않는다. 판정기가 항상 통과하는 장치가 아니라는 것도 코드로 고정했다. 위반을 고의로 주입해 검출되는지 확인하는 반증 테스트가 8 건 이상이다(C08·C11·C16·C17·C18·C20·C21·C23·C24·C25). 이 음성 검증이 없으면 "0 행"은 무결의 증거가 아니라 검증기가 죽어 있다는 증거일 수도 있다.

1.4 남은 기간의 방향

서비스 애플리케이션은 이미 판정 가능한 상태로 서 있다. 남은 6 주는 전부 인프라·배포·운영·보안에 쓴다. 이것은 감출 사실이 아니라 계획의 근거다. 장애를 주입할 대상과 주입 결과를 판정할 술어가 둘 다 준비돼 있으므로, 새 기능을 붙이는 것보다 그 위에서 장애를 재현하는 편이 남은 기간의 한계효용이 크다.

2. 문제 정의와 주제 선정 근거

2.1 출발점: 사용자는 한 문장만 말한다

운영 현장에서 장애는 지표로 도착하지 않는다. 문장으로 도착한다. 사용자가 하는 말은 둘 중 하나다. "안 돼요" 또는 "느려요".

엔지니어의 일은 그 한 문장을 계층으로 좁히는 것이다. 도달이 안 된 것인지, 연결이 안 된 것인지, 응답이 틀린 것인지를 가른다. 계층이 정해지면 담당이 정해진다. L3 이면 네트워크, L4 면 인프라, L7 이면 개발이다. 계층 판단이 곧 책임 소재 판단이다.

이 프로젝트의 문제 정의는 여기서 나온다. 장애를 막는 시스템을 만드는 것이 아니라, 장애가 났을 때 어느 계층인지 근거를 대고 좁히는 절차와, 장애가 지나간 뒤 데이터가 맞는지 기계로 판정하는 절차를 만드는 것이다.

2.2 문제: 대부분의 장애 실습은 사후 판정을 하지 못한다

관점	장애 중 관측	장애 후 판정	판정의 한계
가용성 관측	HTTP 5xx 비율, 다운타임	다시 200 이 나온다	복구는 증명하나 손상 여부는 말하지 못한다
성능 측정	TPS, p99 지연	지연이 기준선으로 복귀	"느렸다"까지만 말한다. 무엇이 틀어졌는지는 지표 밖이다
정합성 판정	위와 동일	데이터가 정답 상태와 일치하는지 SQL 로 대조	도메인이 정답 상태를 정의하고 있어야만 가능하다

응답시간은 사후 무결을 말하지 못한다. 장애 구간에서 주문이 두 번 접수됐는지, 체결이 유실됐는지, 잔고가 원장과 어긋났는지는 p99 가 답하지 않는 질문이다. 판정을 하려면 틀렸을 때 반드시 위반으로 드러나는 정답 상태가 도메인 안에 있어야 한다.

2.3 왜 거래소인가: 판정면이 있는 도메인이기 때문이다

거래소를 고른 것은 개발 취향이 아니라 실험 설계 판단이다. 복식부기 원장이 회계 불변식을 도메인 성질로 이미 갖고 있다. 자산별 원장 합은 0 이어야 하고, 잔고 프로젝션은 원장 재계산과 일치해야 한다. 이 두 명제는 내가 정한 규칙이 아니라 회계가 성립하기 위한 조건이다. 따라서 장애를 주입한 뒤 위반이 나오면 변명의 여지가 없다.

도메인 후보를 같은 기준으로 비교하면 차이가 분명하다.

도메인 후보	정답 상태 정의	장애 후 판정 방법	반증 가능성
게시판·URL 단축기	없음. 글 1 건이 사라져도 "정답"이 없어 위반이 정의되지 않는다	육안 확인	낮음
재고·예약 앱	부분. 수량 음수 금지 정도	단일 제약 조회	중간
부하테스트 대상 서비스	없음. 성능 축만 존재	TPS·p99 비교	중간(성능 한정)
거래소(복식부기 원장)	있음. 자산 보존, 잔고 대 원장 일치, 저널 무결, 멱등	SQL 위반 행 수	높음

이 프로젝트의 판정면은 문장이 아니라 실행 가능한 SQL 이다.

ID	판정 술어	PASS
C01 자산 보존	`SELECT asset_id, SUM(amount) FROM ledger_entries GROUP BY asset_id HAVING SUM(amount) <> 0`	0 행
C02 잔고 대 원장	`SELECT * FROM balance_ledger_check WHERE mismatch`	0 행
C05 명령 저널 무결	`(max(seq) - min(seq) + 1) - count(*)`	0
C07 / C07P 중복 접수	`orders` 및 `command_journal(NEW)`의 (user_id, client_order_id) 중복	0 행
C08 중복 체결	`trades.id` 중복 및 `trade_seq_registry` 1:1 이탈	0 행

2.4 접근 방식의 차이

방법론상의 차이는 세 가지다.

- 주입한다. 장애를 기다리거나 기록하지 않고 스크립트로 만들어낸다. 실험 9 종이 오케스트레이터로 배선돼 있다.
- 정합성으로 판정한다. 복구됐다는 것을 화면이 아니라 원장 SQL 로 판정한다.
- 원인 계층을 지목한다. 계층별 프로브와 패킷 캡처로 좁힌다. 현재 미성립이며 남은 기간의 목표다(3.3 참조).

2.5 실무 연결: 계층 판단이 곧 책임 소재 판단

이 프로젝트가 만드는 것은 결국 "안 돼요" 한 문장을 티켓으로 바꾸는 절차다. 주입한 장애마다 어느 계층에서 어떤 신호가 나오는지를 대응표로 축적한다.

사용자 진술	후보 계층	좁히는 관측	판별 신호	1 차 담당
안 돼요	L3 도달 실패	ICMP 프로브, 경로 추적	응답 없음, 경로 중단	네트워크
안 돼요	L4 연결 실패	TCP 연결 프로브,	SYN 재전송, RST,	인프라

		패킷 캡처	연결 타임아웃	
안 돼요	L7 오류	HTTP 프로브, 애플리케이션 로그	5xx 코드와 에러코드 본문	개발
느려요	L3 지연	RTT·손실률 기준선 대비	RTT 상승, 손실 발생	네트워크
느려요	L4 큐잉·재전송	패킷 캡처	재전송 급증, 윈도우 축소	인프라
느려요	L7 처리	애플리케이션 메트릭	p99 상승, DB 대기 증가, 커넥션 풀 포화	개발

이 구조는 실제 사례로 한 번 검증됐다. nginx 가 POST 를 재시도하지 않는 기본 규약 때문에 구 리더가 팔로워로 재합류하는 구간에서 `POST /api/v1/orders` 가 전량 503 이었고 `GET /api/v1/orderbook` 은 200 이었다(2026-08-18 실측). 증상은 "주문이 안 돼요" 한 문장이지만, 조회는 되고 쓰기만 막힌다는 계층 신호가 원인을 L7 프록시 설정으로 좁혔다. `non_idempotent` 추가와 reload 만으로 20 초 안에 체결 599 건이 재개됐다. 다만 강등 노드가 업스트림에서 빠지지 않으므로 약 1.25%의 POST 실패 바닥이 남는다. 이 잔여도 한계로 기록한다. 관측 1 회 사례이므로 계층 판단의 예시로 쓰고 인과 확정 사례로 제시하지 않는다.

3. 현재 진척과 남은 범위

3.1 규모 실측

빌드 산출물(build/, .next/, out/, node_modules/)과 워크트리 사본은 계측에서 제외했다.

항목	실측
커밋	220 건
기간	2026-07-22 ~ 2026-08-25 (스팬 35 일, 커밋이 찍힌 작업일 9 일)
Java 파일	245 (engine main 10 + engine test 4 + app main 176 + app test 55)
서버 코드 줄수	engine main 1,099 / app main 18,768
웹 TS·TSX	150 파일 23,749 줄
웹 CSS 모듈	37 파일

백엔드 테스트	57 클래스 376 메서드 (app @Test 329 + engine @Test 43 + jqwik @Property 4). @Disabled 0 건
웹 테스트	286 건 전건 통과
Flyway 마이그레이션	14 개 (V0~V13, 결번 없음)
DB base 테이블	46 (public 41 + harness 5). 파티션 포함 CREATE TABLE 96
PL/pgSQL 함수·뷰·시퀀스	18 / 5 / 1
REST 엔드포인트	81 (공개 38 · 관리 38 · 하네스 4 · 내부 1)
WebSocket	엔드포인트 1(`/ws/v1`), 채널 6 종(공개 4 + 비공개 2)
웹 page 라우트	22 종
정적 export 산출	66 페이지 + 404.html, 6.3MB
카오스 실험 스크립트	9 종 + 공용 3 종 = 12 파일, 본문 2,413 줄
카오스 compose 서비스	9 (상시 6 + 1 회성 1 + obs 프로파일 2)
Prometheus·Grafana	레코딩 룰 9 · 알람 11 · 대시보드 4 종
CI 워크플로	3 (ci-backend · ci-web · style)
docs 산출물	34 항목

기간 주석. 저장소가 뒷받침하는 사실은 커밋 스팬 35 일·작업일 9 일이다. 연간 범위 대비 진척률 같은 추정 비율은 분모를 뒷받침할 산출물이 없으므로 쓰지 않는다.

3.2 구현된 것

영역	상태
엔진 결정론 코어	완료. `server/engine` 은 서드파티 import 0 건의 순수 Java. OrderBook·MatchingEngineImpl·SingleWriterLoop·SnapshotCodec
저널 계층	완료. command append + fsync ACK. append-only 를 forbid_mutation 트리거가 ROW·STATEMENT 두 겹으로 물리 차단
리더 리스·fencing	완료. DB `leader_lease` 조건부 UPDATE, epoch +1, assert_current_leader 3 지점 호출
복식부기 정산	완료. 단일 트랜잭션. 봉인 가드 3 종
REST·WS 게이트웨이	완료. 멱등·서명·nonce·잔고 사전 가드. REST 81, WS 채널 6 종
스냅샷·복구	완료. format_version·engine_version·config_hash 일치와 마켓별

	state_checksum 대조를 통과한 세트만 채택. 어긋나면 세트 전체 폐기 후 seq 0 전량 재생
봇 플릿	완료. 12 마켓, 마켓메이커 14 + 테이커 12, 봇당 가상 스레드 1 개, 시드 SplittableRandom 고정 순서
불변식 검증기	완료. 26 개 체크 상시 실행(리더 노드 5 분 fixedDelay), 반증 테스트 8 건 이상
카오스 토폴로지·오케스트레이터	완료. E1~E9 배선, RTO 측정 체인
관리 평면	완료. 분리 포트 8443, mTLS `client-auth: need`, 2 인 승인, append-only 감사
회원·커뮤니티	코드·통합테스트 반영 완료. 완료 기준인 부하 동시 실행 검증은 미실행

3.3 비어 있는 것

미성립을 미성립으로 적는 것이 이 계획서의 기본 규율이다. 아래가 남은 6 주의 작업 목록 그 자체다.

축	현재(2026-08-25)	남은 기간 목표
정합성 판정	성립. 불변식 26 개 상시 검증, 라이브 PASS 5 건	유지. 실험 산출물을 파일로 보존하는 배선 추가
자동 복구	부분 성립. E2·E5·E7 실측 RTO 확보. E4 는 술어 교체 후 재측정 필요	E4 RTO 확정
계층 판정	미성립. 계층별 프로브 0 건, node_exporter·cAdvisor 0 건, tcpdump 미사용	tc netem 주입, ICMP·TCP·HTTP 3 계층 프로브, 패킷 근거
부하 축	미성립. k6 시나리오 4 종(order_flow.js 305 줄)은 실재하나 실행 배선 0 건	실행 배선과 실측
데이터 이중화	미성립. PostgreSQL 단일 인스턴스. RPO=0 은 단일 인스턴스 범위에서만 성립	스트리밍 복제 구성과 성립 범위 재기술
로그	미성립. 노드 4 개 로그가 분산	중앙화
부하 분산	미성립. nginx 가 api-1 1 차 / api-2	리더 인지 능동 분산

	backup 정적 승계라 평시 분산이 0	
외부 공개	미성립. 로컬 Docker 한정	클라우드 배포, TLS 종단, 방화벽 정책
인프라 보안	미성립. DB 계정 권한 분리 미적용, 컨테이너 하드닝 지시자 0 건, 호스트 공개 포트 7 개	권한 분리 실증, 하드닝, 노출면 축소
배포 자동화	미성립. CI 3 종은 빌드 검증까지만	이미지 파이프라인 + 무중단 롤링

3.4 미구현으로 남기는 애플리케이션 기능

남은 기간을 인프라에 쓰기로 했으므로 아래는 미구현으로 확정하고 계획서에 이름으로 적는다.

항목	상태
API 키 발급·회전·폐기 3 종	미구현. server 전 Java 소스에 `/keys` 매핑 0 건
관리 평면 3 종(봇 제거, 시나리오 프리셋, 텔레메트리 WS)	미구현
orders/batch·일괄 취소·orders/chance·my/trades·my/ledger	서버 구현 완료, 웹 미연동
V3 통합테스트 T1~T6	스텁만 존재. `integrationTest` sourceSet 부재
C16 외부 ACK 파이프라인 자동화	k6 방출단과 psql 적재 절차는 문서화, 그 사이 자동화 없음

4. 기술 스택과 선택 사유

버전은 build.gradle.kts, package-lock.json, compose, 빌드된 app.jar 의 실해석 값이다.

4.1 서버 런타임

구성	버전	선택 사유
Java	21 (Temurin)	가상 스레드를 표준으로 쓰는 최초 LTS. 요청당 스레드 모델을 유지한 채 동시성 상한을 올린다
Spring Boot	3.5.16 (Framework 6.2.19)	BOM 이 보안·전이 의존 버전을 일괄 고정해 핀 드리프트를 줄인다

서블릿 컨테이너	Tomcat embed 10.1.55	Boot 기본. 별도 채택 사유 없음
커넥션 풀	HikariCP 6.3.3	리스 전용 풀과 요청 풀을 분리 배분해야 해서 풀 단위 계측·격리가 필요
동시성	Virtual Threads	봇 플릿이 봇당 1 스레드를 쓰는 구조라 플랫폼 스레드로는 수백 봇을 못 띄운다
DB	PostgreSQL 17-alpine (JDBC 42.7.11)	NUMERIC(40,18) 정확 산술, DEFERRED CONSTRAINT TRIGGER, 파티셔닝, 조건부 UPDATE 기반 리더 리스를 한 엔진에서 얻는다
마이그레이션	Flyway 11.7.2	DDL 정본 문서를 버전 파일로 1:1 대응시켜 스키마 드리프트를 커밋 단위로 추적
빌드	Gradle 8.14	멀티모듈 분리(engine·app)와 BOM 위임을 동시에 만족
내결함	Resilience4j 2.4.0	적용 범위는 chaosProbe 서킷브레이커 1 개. 거래 경로 레이트리밋은 자체 구현
비밀번호	spring-security-crypto 6.5.11 (Argon2id)	검증된 KDF 구현을 직접 만들지 않는다
서명	bcprov-jdk18on 1.80 (Ed25519)	회원 세션 토큰 서명. JDK 표준 제공 범위 밖이라 명시 핀
정규화	java-json-canonicalization 1.1 (RFC 8785 JCS)	API 서명 canonical 과 멱등 내용 비교의 공통 원천. 직렬화 차이로 멱등키가 갈리는 것을 막는다
메트릭	micrometer-registry-prometheus 1.15.12	판정을 메트릭 임계로 하므로 스크레이프 가능한 노출이 필수

4.2 웹

구성	버전	선택 사유

Next.js	15.5.20 (`output: "export"`)	정적 export 로 산출물을 파일로 고정. 런타임 서버 의존 없이 배포·검증 가능. 오리진 장애와 웹 가용성을 분리할 수 있다
React	19.2.7	Next 15 기본 런타임
TypeScript	5.9.3	금액·수량을 문자열로 다루는 계약을 타입으로 강제
@stomp/stompjs	7.3.0	서버 STOMP 브로커와 프로토콜 동일. 자체 프레이밍 구현 회피
klinecharts	9.8.12	메인 캔들·기술적분석 차트
lightweight-charts	5.2.0	대시보드 미니 차트. 지표 없이 가볍게 그리는 용도로 분리
zustand	5.0.14	고객·관리자 스토어 분리. 실시간 갱신이 트리 전체를 리렌더하지 않게 한다
pretendard	1.3.9	로컬 번들 폰트. 런타임 외부 의존 금지 규칙과 충돌하지 않는다
Node (CI)	22, `npm ci` 락파일 고정	빌드 재현성

4.3 검증·관측

구성	버전	선택 사유
Toxiproxy	2.12.0	앱 코드 수정 없이 DB 경로에 지연·단절 주입
Chaos Monkey for Spring Boot	3.3.0	프로세스 내부 결함 주입. 프로파일 게이트로 프로덕션 경로와 분리
k6	v2.1.0 (문서 핀)	부하 시나리오. 현재 실행 배선 없음
Prometheus	v3.13.0	레코딩 룰 9 · 알람 11
Grafana	13.1.0	대시보드 4 종 파일 프로비저닝
nginx	1.29	카오스 토폴로지의 LB. 오픈소스 판이라 능동 health_check 없음

Testcontainers	Boot BOM 위임	통합테스트가 실제 PostgreSQL 17 에서 돌아야 트리거·제약까지 검증된다
JUnit 5 (BOM 5.11.4), jqwik 1.9.2		엔진 결정론은 예제 테스트가 아니라 속성 기반으로 검증

4.4 인프라 스택과 선택 사유

이 절이 공지가 명시 요구한 항목이다. 아래는 6 주에 새로 도입하는 구성이다.

구성	선택	선택 사유
호스트 OS	Rocky Linux 10.2 (로컬 VM), Rocky Linux 10 AMI (클라우드)	로컬·클라우드 OS 를 동일 배포판으로 맞춰 nftables·SELinux 거동을 같게 한다. RHEL 10 계열은 iptables 가 제거돼 nftables 가 유일 인터페이스이며, SELinux·firewalld 기본 활성이 보안 축의 실물 근거가 된다
가상화	VMware Workstation	개발 데스크톱에서 Docker 를 Windows 가 아니라 Linux VM 안에서 돌린다. 한글 경로·Windows 컨테이너 계열 마찰을 구조적으로 제거
컨테이너 런타임	Docker CE	카오스 스크립트 9 종이 `docker kill`·`docker pause`·`docker network disconnect` 를 직접 호출한다. 런타임 교체는 하네스 전면 개편을 부른다
오케스트레이터	채택하지 않음. 노드별 compose + 프라이빗 IP 주입	Swarm overlay 는 VXLAN 캡슐화를 한 겹 더 얹어 tc netem 이 무엇을 측정하는지 흐린다. k8s·ECS 는 스케줄러가 컨테이너를 자동 재기동해 kill 실험 관측을 오염시킨다. 오케스트레이터

		미채택은 기능 축소가 아니라 측정 대상 보존이다
클라우드	AWS ap-northeast-2	리전 내 왕복 지연이 RTO 측정에 잡음을 덜 섞는다. 미국 리전은 EC2 20%·아웃바운드 29% 싸지만 왕복 150ms 이상이 측정을 오염시킨다
컴퓨트	EC2 (Graviton t4g·c7g)	OS 셸 접근이 필요하다. tc netem·nftables·커널 파라미터·SIGSTOP 은 관리형 계층에서 불가능하다. Graviton 은 x86 대비 상시면 월 20% 저렴
DB	EC2 자체 운영 PostgreSQL 17 (RDS 비채택)	5 절·8 절 참조. 증명하려는 명제가 장애 아래의 무결과 복구인데, 장애를 주입할 권한이 없는 계층은 증명 대상에서 빠진다
로드밸런서	edge 노드의 nginx (ALB 비채택)	LB 계층 자체가 실험 대상(리더 인지 라우팅)이라 설정 가시성이 필요하다. 월 약 USD 22 절감
NAT	edge 노드의 nftables masquerade (NAT Gateway 비채택)	월 USD 43.07 절감. 동시에 nftables 실물 근거가 된다
정적 웹	S3 + CloudFront + ACM + Route 53	앱 노드 자원을 쓰지 않고, 오리진 장애와 웹 가용성을 분리한다. EC2 전체를 죽이는 실험 중에도 웹은 200 을 돌려준다. 프리티어 범위 안이라 비용 0
관측	Prometheus·Grafana·Loki 자체 운영 (CloudWatch 비채택)	레코딩 룰 9·알람 11·대시보드 4 종이 이미 파일로 존재하고 CI 가 promtool 로 검증한다. 서울 리전 CloudWatch 로 옮기면 월 약 USD 190 이 든다(추정 기반)
시크릿	SSM Parameter Store SecureString (Secrets Manager 비채택)	시크릿당 월 USD 0.40 회피. 표준 파라미터로 충분

관리자 접근	SSM Session Manager (SSH 폐쇄)	인바운드 22 를 아예 열지 않는다. 세션 로그가 그 자체로 감사 증거
CI/CD 인증	GitHub Actions OIDC 페더레이션	장기 액세스 키를 발급하지 않는다. 키 유출 경유 과금 사고 경로를 구조적으로 차단
IaC	Terraform (스트레치)	증명면을 매 회차 생성·파기하는 운용에 필요. 예비 시간 조건 충족 시에만 착수

5. 시스템 아키텍처

5.1 모듈 구성

모듈	규모	성질
`server/engine`	main 10 파일 1,099 줄, test 4 파일	순수 Java. main 소스 import 가 전부 `java.*` 표준 라이브러리, 서드파티 0 건. Spring·락·I/O·벽시계·난수 금지
`server/app`	main 176 파일 18,768 줄, test 55 파일	패키지 분포: api 69, admin 22, engine 19, sim 16, journal 16, config 9, harness 8, ledger 5, dev 4, chaos 4, snapshot 3, 루트 1
`web`	150 파일 23,749 줄	Next.js 정적 export
`harness`	compose · 스크립트 12 · k6 자산 · SQL 카탈로그 · Prometheus 룰 · Grafana 대시보드	검증 장치

[그림 1] 모듈 구성과 의존 방향

5.2 3 계층 SoT (Source of Truth)

계층	테이블	성질
① 복구 원천	command_journal, event_journal,	append-only. UPDATE·DELETE 를 forbid_mutation 트리거가

	snapshots	ROW·STATEMENT 두 겹으로 물리 차단. 재생 가능
② 회계 원천	ledger_transactions, ledger_entries	복식부기. 자산별 합 0. 봉인 가드 3 종(assert_txn_sealed_balanced · guard_sealed_txn · guard_txn_transition)
③ 파생 프로젝션	balances, orders, trades, position_cost	언제든 재계산 가능. position_cost 는 rebuild_position_cost 로 재구축

balance_ledger_check 뷰가 잔고 대 원장 합의 불일치를 mismatch 열로 노출한다. 증명 ②는 ①의 명령 재생으로, 증명 ①은 ②의 자산 보존 불변식으로 각각 판정한다.

[그림 2] 3 계층 SoT 와 판정 흐름

5.3 고가용성 기제

기제	구현
단일 라이터 보장	DB `leader_lease` 단일 행(resource='matching-engine'). 부트스트랩 시드 INSERT
리더 획득	`try_acquire_leader` 가 `lease_until < clock_timestamp()` 조건부 UPDATE 로 epoch 를 +1 해 반환
리스 갱신	`renew_leader_lease` 가 holder·epoch 일치와 미만료를 조건으로 갱신
쓰기 펜싱	`assert_current_leader` 가 holder 불일치·epoch 불일치·리스 만료를 각각 EXCEPTION 으로 던진다. 자산 변경 트랜잭션이 커밋 전에 호출한다(CommandJournalAppender · EventJournalAppender · SettlementService 3 지점). stale 리더의 쓰기는 롤백된다
split-brain 감사	command_journal 은 fencing_token, event_journal·trades·snapshots 는 fencing_epoch 에 승격 epoch 를 저장. 데이터로 사후 감사 가능

수용 제한	쓰기·조회 2 버킷 + 재조회 전용 소형 버킷. 초과는 거절이 아니라 판정 보류(409 requery_deferred + Retry-After). 인증 앞단 전용 필터로 배치해 인증 연산 비용 자체를 상한 안에 둔다
좀비 리더 자발적 강등	쓰기 수요 대비 쓰기 커밋 완료율이 임계 미만으로 지속되면 리스 갱신을 포기하고 강등. 판정 규칙을 LeaderStallDetectorTest 가 단위 고정
스냅샷 채택 게이트	format_version·engine_version·config_hash 일치와 마켓별 state_checksum 대조를 통과한 세트만 채택. 어긋나면 세트 전체 폐기 후 seq 0 전량 재생. 세트가 단일 트랜잭션 INSERT 라 부분 세트가 관측되지 않는다

[그림 3] 리더 리스·펜싱 상태 전이와 페일오버 타임라인

5.4 배포 단위 분리

평면	내용
A 거래 평면	다중 인스턴스 전제. 카오스 토폴로지에서 chaos-api-1 · chaos-api-2
B 봇 플릿	외부 클라이언트 규약(서명·자체 HTTP)만 사용. 내부 직호출 0 건. 카오스 스택에서는 엔진을 끈 별도 노드로 분리해 승격 주체 오염을 막는다
C 관리 평면	분리 포트 8443 · 분리 네트워크 · mTLS. `exchange.admin.enabled=true` 조건부 등록

6. 인프라와 배포 설계

6.1 이 축의 요구와 충돌

학교 공지의 필수 조건은 "반드시 배포하여 외부에서 접속 가능한 상태로 서비스할 것"이다. 동시에 이 프로젝트의 증명 수단은 장애 주입이다. 두 요구가 정면으로 충돌한다.

#	요구	충돌 지점

R1	외부 도메인으로 상시 접속 가능	실험이 서비스를 망가뜨린다
R2	커널 계층 장애 주입(tc netem, nftables, SIGSTOP) 가능	관리형 서비스는 OS 접근이 없다
R3	노드 간 실제 네트워크 분단 관측	한 호스트에 컨테이너를 몰면 해소되지 않는다
R4	발표 노트북 RAM 8GB 로 시연	로컬 전체 스택 구동 불가
R5	비용이 상한 안에 든다	R1 의 상시성과 정면 충돌

해결 원칙은 평면 분리다.

평면	구동	허용 실험	근거
상시면(service)	24 시간	비파괴 실험만. 리더 kill, 롤링 배포	자동 복구가 RTO 30 초 이내이므로 상시 서비스와 양립한다
증명면(proof)	실험·발표 창에서만	전 실험. tc netem, nftables DROP, PG 프로세스 정지, 커널 파라미터 조작	회복 불가 상태를 만들어도 상시면에 도달하지 않는다

AWS 는 리허설 장소가 아니라 본실행 장소다. 파괴 실험을 로컬 Rocky VM 에서 수렴시킨 뒤 확정 회차만 AWS 에서 재현한다. 이것이 증명면 가동시간을 창 구동으로 억제하는 근거이고, 비용 산정 전체를 지탱하는 전제다.

6.2 관리형 대 자체 운영: RDS 를 쓰지 않는다

축	RDS PostgreSQL	EC2 자체 운영	판정
OS 셸 접근	없음	root	자체 운영 필요
DB 경로에 tc netem 지연·손실·재정렬 주입	불가	가능	자체 운영 필요
nftables 로 5432 블랙홀(RST 없는 DROP)	불가	가능	E2 재현에 필수
커널 파라미터(keepalive, somaxconn, conntrack)	불가	가능	좀비 커넥션 회수 실험의 원천

조작			
PG 프로세스 SIGSTOP·kill -9	불가	가능	E7 계열에 필수
자동 백업·PITR·Multi-AZ 페일오버	제공	직접 구축	자체 운영 시 손실
월 비용(최소 등급)	Multi-AZ 약 USD 85	EC2 2 대 + 80GiB 약 USD 53	자체 운영이 저렴

선택 사유를 한 문장으로 적는다. 이 프로젝트가 증명하려는 명제는 장애 아래에서의 무결과 복구다. 장애를 주입할 권한이 없는 계층은 증명 대상에서 빠진다. RDS 를 채택하면 DB 계층 전체가 증명 범위 밖으로 나가고, 남은 명제는 앱 계층 페일오버로 축소된다.

대가는 정직하게 계상한다. RDS 가 대신 해 주던 것을 직접 만든다.

RDS 가 주던 것	자체 구현 대체안	6 주 내 도달 목표
자동 스냅샷	EBS 스냅샷 일 1 회 + pg_basebackup 주 1 회	배선 완료
PITR	WAL 아카이빙을 S3 로	배선 완료, 복원 리허설 1 회
Multi-AZ 페일오버	스트리밍 복제 standby + 수동 승격 스크립트	standby 동기화까지. 자동 승격(Patroni)은 스트레치로 분리
자동 패치	dnf-automatic security only	배선 완료

이 작업이 현재 한계 "RPO=0 은 단일 PostgreSQL 인스턴스 범위에서만 성립한다"를 실제로 겨냥한다.

6.3 목표 아키텍처

`

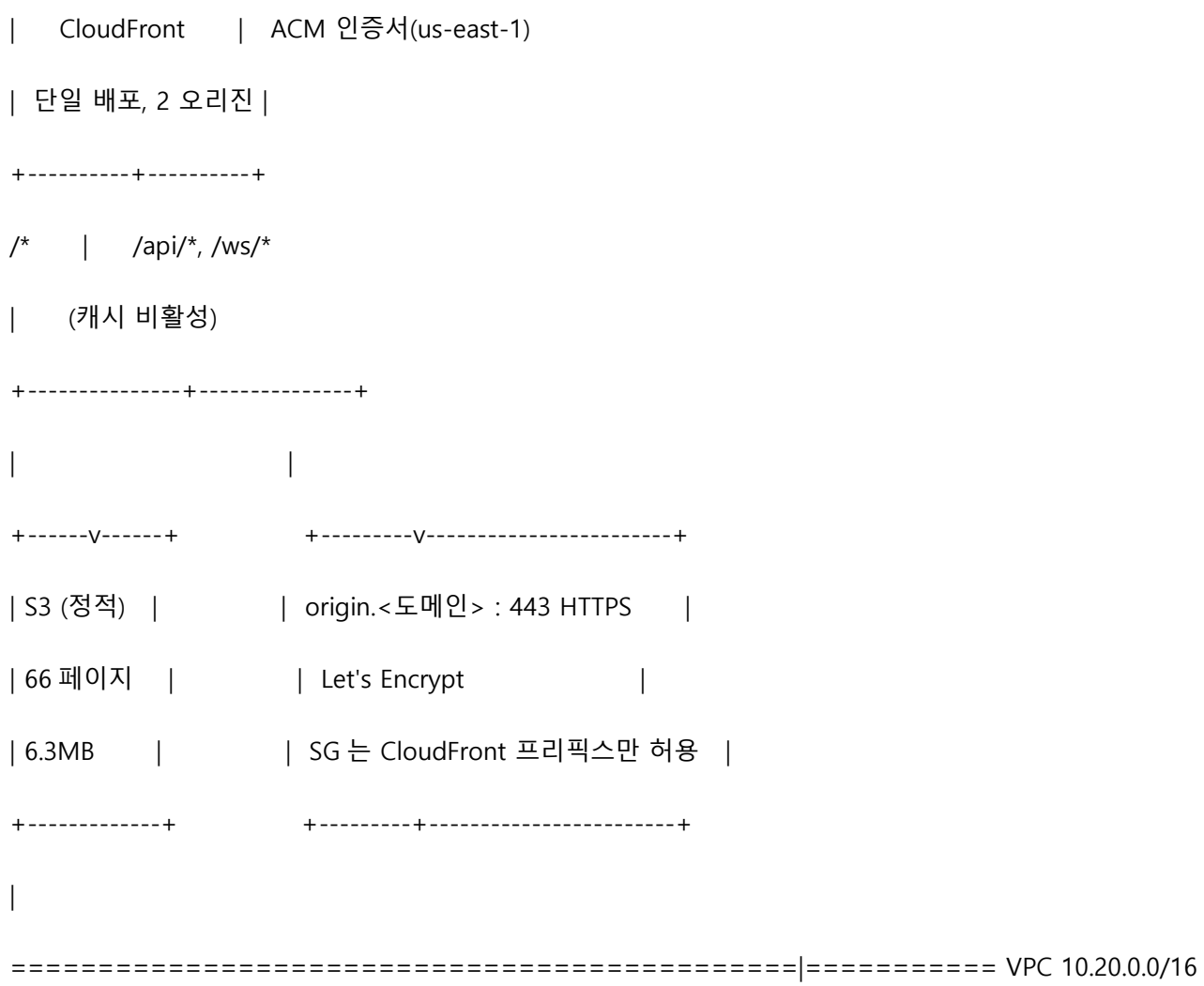
[사용자 브라우저]

|

HTTPS 443

|

+--------------------+


| CloudFront | ACM 인증서(us-east-1)
| 단일 배포, 2 오리진 |
/* | /api/*, /ws/*
| (캐시 비활성)
| |
S3 (정적)		origin.<도메인> : 443 HTTPS
66 페이지		Let's Encrypt
6.3MB		SG 는 CloudFront 프리픽스만 허용
========== VPC 10.20.0.0/16
퍼블릭 서브넷 10.20.0.0/24 |
| edge (t4g.micro) |
| nginx TLS 종단 · 리더 인지 사이드카 · nftables masquerade(NAT) |
| node_exporter · blackbox_exporter · SSM 배스천 |
| 8080 / 8081 / 5432
프라이빗 서브넷 10.20.10.0/24

| core (t4g.medium) : exchange-app(리더) · PostgreSQL 17 primary |

| Prometheus · Loki · Grafana |

+----------+

--- 증명면 (창 구동, terraform apply / destroy) ---

app-2 (c7g.large) · pg-standby (t4g.small) · obs (t4g.medium) · load (c7g.large)

`

[그림 4] 목표 클라우드 아키텍처 구성도

6.4 네트워크와 보안그룹

서브넷	CIDR	라우팅	배치
public-a	10.20.0.0/24	0.0.0.0/0 -> IGW	edge
private-a	10.20.10.0/24	0.0.0.0/0 -> edge ENI(NAT 인스턴스)	core, 증명면 노드

최소권한을 소스 SG 참조로 표현하고 CIDR 하드코딩은 관리자 접속 1 건으로 제한한다.

SG	방향	포트	소스	사유
sg-edge	in	443/tcp	CloudFront 관리형 프리픽스 리스트	오리진 직접 우회 차단
sg-edge	in	443/tcp	관리자 고정 IP/32	실험 중 오리진 직접 관측
sg-edge	in	80/tcp	0.0.0.0/0	Let's Encrypt HTTP-01 한정. 그 외 경로는 301
sg-app	in	8080/tcp	sg-edge	LB 경유만 허용
sg-app	in	8081/tcp	sg-edge	actuator. prod 프로파일이 관리 포트를 8081 로 분리한 실제 값
sg-app	in	9100, 8083	sg-edge	node_exporter,

				cAdvisor
sg-data	in	5432/tcp	sg-app, sg-edge	앱 노드와 Grafana 읽기 전용 롤
전 노드	in	22/tcp	없음	SSH 미개방. 접속은 SSM Session Manager

OS 계층 방어를 SG 와 이중화한다.

계층	수단	검증
AWS	보안그룹 + NACL	외부 포트 스캔으로 열린 포트 목록 대조
OS	nftables(firewalld 백엔드) 존별 룰	`nft list ruleset` 스냅샷을 저장소에 커밋
프로세스	SELinux enforcing 유지	`getenforce` = Enforcing, `ausearch` denial 0 건
DB	롤 분리	앱 계정으로 DDL 시도 시 SQLSTATE 42501

6.5 노드 사이징

근거는 저장소 실값이다.

항목	실값	출처
앱 컨테이너 메모리 상한	1GiB(api), 512MiB(봇)	docker-compose.chaos.yml `deploy.resources.limits.memory`
JVM 힙 상한	컨테이너 상한의 75% = 768MiB	Dockerfile.app - `XX:MaxRAMPercentage=75`
app.jar 크기	45.7MB	실측
앱 노드 DB 커넥션	32 + 리스 전용 2	application.yml prod 프로파일
정적 export	66 페이지 + 404.html, 6.3MB	web/out 실측

노드	계산	요구 RAM

앱 전용	컨테이너 1.0GiB + Rocky minimal 약 250MiB + dockerd 약 80MiB + exporter·promtail 약 60MiB	약 1.4GiB
DB	shared_buffers 512MiB + 커넥션 약 10MiB x 68 + OS·에이전트 약 390MiB	약 1.6GiB

판정. 프리티어 t3.micro·t4g.micro(1.0GiB)는 앱 컨테이너 상한 1GiB 하나만으로 RAM 전량을 소진하므로 앱 노드가 될 수 없다. 앱 전용 노드의 최소 단위는 2GiB 등급(t4g.small)이다. 상시면 core 는 앱·DB·관측을 함께 담으므로 4GiB 등급(t4g.medium)을 쓴다.

이 계산은 계산이지 실측이 아니다. 커넥션당 약 10MiB 는 일반 추정치이며 이 워크로드에서 계측한 값이 아니다. W2 에 실측으로 교체한다.

6.6 외부 노출면

정적 export 66 페이지(6.3MB)의 서빙 경로를 결정한다.

안	웹 가용성	CORS	판정
nginx 단독 서빙	앱 노드와 운명 공유	불요	필수 조건 R1 이 실험에 인질로 잡힌다
S3 + CloudFront 단독	앱과 독립	필요	CORS·WS 오리진 화이트리스트가 늘어난다
CloudFront 2 오리진	앱과 독립	불요(same-origin)	채택

경로 패턴	오리진	캐시 정책	사유
`/*` (기본)	S3 (OAC 로 비공개)	CachingOptimized	빌드 산출물이므로 캐시 가능
`/api/*`	origin.<도메인>	CachingDisabled + AllViewer	인증 헤더·서명·멱등키를 그대로 전달해야 한다
`/ws/*`	origin.<도메인>	CachingDisabled	WebSocket 업그레이드. heartbeat 10s/10s 라 idle 타임아웃이 발생하지

			않는다
/actuator/*, /admin/*, /harness/*	라우팅 없음		외부 노출 대상이 아니다

이 배치가 주는 것.

1. 브라우저 관점 same-origin 이 되어 CORS·WS 오리진 화이트리스트 추가 작업이 0 이 된다.
2. EC2 전체를 죽이는 실험 중에도 https://<도메인>이 200 을 돌려준다. 웹은 살고 API 만 5xx 인 상태가 되며, 이것이 R1 을 실험과 양립시키는 핵심 장치다.
3. 실험 판정은 CloudFront 뒤가 아니라 VPC 내부 오리진 직접 측정으로 한다. CF 의 재시도·캐시가 RTO·오류율 계측에 섞이지 않는다.

노출하지 않는 것.

대상	접근 경로	사유
관리 평면 8443 mTLS	SSM 포트 포워딩	클라이언트 인증서 기반이며 파괴 액션과 2 인 승인을 다룬다
actuator 8081	edge 노드 내부 스크레이프만	prod 프로파일이 고객 평면 8080 에서 actuator 를 완전 분리
Prometheus 9090, Grafana 3000	SSM 포트 포워딩	원장 보존 신호를 담는다
harness API	exchange.harness.enabled=false 로 상시면 미등록	증명면에서만 true
PostgreSQL 5432	프라이빗 서브넷	

6.7 웹 빌드 파라미터 (배포 선행 조건)

정적 export 는 NEXT_PUBLIC_* 값을 빌드 타임에 번들로 인라인한다. 도메인이 정해지기 전에는 배포용 웹을 빌드할 수 없다.

변수	배포 값	근거
NEXT_PUBLIC_DATASOURCE	http	이 값이 아니면 시뮬레이터가 붙어 실서버 데이터가 나오지 않는다
NEXT_PUBLIC_API_BASE	"" (빈 문자열)	same-origin 상대 경로. CloudFront 2 오리진 배치의 이득을 여기서 회수

NEXT_PUBLIC_WS_BASE	wss://<도메인>	빈 apiBase 에서 상대 경로가 만들어지는데 STOMP 클라이언트는 절대 URL 을 요구한다

도메인 확보를 W1 최우선 작업으로 두는 이유가 여기 있다.

6.8 도메인과 TLS

구간	방식	종단
브라우저 -> CloudFront	TLS 1.2+ / ACM(us-east-1, 자동 갱신)	CloudFront
CloudFront -> edge nginx	TLS 1.2+ / Let's Encrypt	nginx
edge nginx -> app	평문 HTTP	없음. 같은 VPC 프라이빗 서브넷, sg-app 인바운드가 sg-edge 만 허용. 암호화 대신 네트워크 격리로 방어하며 이 선택을 문서에 남긴다
app -> PostgreSQL	평문	동상
운영자 -> 관리 평면	TLS 1.2 + mTLS(client-auth: need)	Spring SSL. 기존 구현

certbot 갱신 실패가 서비스 중단으로 이어지는 경로를 막는다. `certbot renew --dry-run` 을 주간 systemd timer 로 돌리고 실패 시 Prometheus 알람을 낸다. 엣지가 ACM 자동 갱신이므로 오리진 인증서가 만료돼도 사용자 관점 TLS 는 유지되고 502 로 나타난다. 이 차이를 대시보드에 분리 표기한다.

6.9 로컬 VM 과 클라우드의 동형화

이식이 아니라 동형화가 목표다.

계층	로컬	클라우드	동일성 보장
OS	Rocky Linux 10.2 (VMware)	Rocky Linux 10 AMI	동일 배포판. nftables·SELinux 거동이 같다
컨테이너 런타임	Docker CE	Docker CE 동일 마이너	설치 스크립트 공유
앱 이미지	GHCR pull	GHCR pull	동일 digest. 로컬 빌드

			이미지를 올리지 않는다
DB 이미지	postgres:17-alpine	동일 태그 고정	compose 공통 파일
스키마	Flyway V0~V13	동일	기동 시 버전 대조
설정	환경변수·파일 시크릿	동일	코드 변경 0

compose 파일을 오버레이로 분리한다. 현행 `docker-compose.chaos.yml` 은 단일 호스트 전제(container_name 고정, 서비스명 DNS 의존)라 그대로는 다중 호스트에 얹히지 않는다.

`

deploy/

compose.base.yml 서비스 정의, 이미지 태그·환경변수는 변수 참조

compose.local.yml 전 서비스 1 호스트, dev 프로파일

compose.node-app.yml 앱 노드 1 개분, prod 프로파일

compose.node-data.yml PostgreSQL 1 개분

compose.node-edge.yml nginx + 관측

.env.example 변수 카탈로그(값 없음, 커밋 대상)

`

6.10 배포 자동화와 무중단 배포

현행 워크플로 3 종은 빌드 검증에서 끝난다. 2 종을 추가한다.

워크플로	트리거	내용
`image.yml`	main push (server/**)	buildx 로 `ghcr.io/.../exchange-app:${sha}` 빌드·푸시. 캐시 `type=gha`
`deploy.yml`	workflow_dispatch + main push, `environment: production`(수동 승인)	웹·앱 배포. AWS 인증은 OIDC

`deploy.yml` 단계.

#	단계	실패 시
1	선행 게이트 확인(ci-backend·ci-web·style 전부 success)	중단
2	`NEXT_PUBLIC_*` 주입 후 웹 빌드, out/ 산출물 존재 검증	중단
3	`aws s3 sync web/out ... --delete`	중단
4	CloudFront 캐시 무효화	재시도 1 회
5	SSM Run Command 로 앱 노드 순차 교체	자동 롤백
6	사후 불변식 권위 run + 외부 프로브	자동 롤백

무중단 롤링 절차. leader lease 구조 때문에 순서가 중요하다. 팔로워를 먼저, 리더를 나중에 교체한다.

#	동작	판정
1	`GET /admin/v1/ha/status` 로 현 리더 식별	리더 1 개 확정
2	팔로워를 nginx upstream 에서 drain 후 `nginx -s reload`	reload 는 워커를 graceful 교체하므로 in-flight 요청이 끊기지 않는다
3	팔로워 `docker compose pull && up -d`	liveness 200 대기, 상한 90 초
4	drain 해제 후 reload	upstream 복귀
5	불변식 권위 run 1 회	위반 0 행. 아니면 중단·롤백
6	리더 컨테이너 SIGTERM	리스 TTL 만료 후 팔로워 승격
7	신 리더 확인	holder 변경, epoch +1
8	구 리더를 신 이미지로 기동	팔로워로 재합류
9	사후 불변식 권위 run + `POST /harness/v1/failover` 로 RTO 기록	위반 0 행, RTO 30 초 이내
10	실패 시 직전 태그로 재기동	롤백 완료 확인

6~9 단계가 계획된 리더 교체이므로 E4 와 같은 경로를 탄다. 배포가 곧 페일오버 리허설이 되고, 배포 로그가 곧 RTO 증거가 된다.

6.11 nginx 리더 인지 라우팅

현행 nginx 는 api-1 1 차 / api-2 backup 정적 승계라 평시 부하 분산이 0 이고, 강등 노드가 업스트림에서 빠지지 않아 약 1.25%의 POST 실패 바닥이 남는다. 오픈소스 nginx 에는 능동 health_check 가 없다.
다음으로 교체한다.

요소	설계
업스트림 파일 분리	`include /etc/nginx/upstream-leader.conf`
갱신 사이드카	2 초 주기로 두 노드의 `/actuator/health/readiness` 폴링. 팔로워는 설계상 503(REFUSING_TRAFFIC)이라 리더 판별이 그대로 된다
쓰기 라우팅	리더 노드 단독 upstream
조회 라우팅	두 노드 `least_conn` 분산. 평시 분산 0 을 해소
안전망	기존 `proxy_next_upstream ... http_503 non_idempotent`, `tries 2` 유지. 사이드카 지연 구간을 덮는다

6.12 발표 노트북 8GB 제약 해소

항목	로컬 구동 시	배포 후
웹	정적 서버 프로세스	브라우저 탭
API 2 노드	약 2.0GiB	0
PostgreSQL	약 0.5GiB	0
봇 플릿	약 0.5GiB	0
Prometheus·Grafana	약 0.5GiB	브라우저 탭(SSM 포트 포워딩)
실험 실행	PowerShell + Docker Desktop	SSM Session Manager 터미널 1 개
합계	약 3.5GiB 이상. 8GB 노트북의 실사용 한계	0.5GiB 미만

발표 시나리오는 브라우저 탭 3 개(서비스 도메인, Grafana, 실험 로그)와 SSM 터미널 1 개로 성립한다. 네트워크 장애 대비로 실험 산출물(verdict JSON, DB 덤프, 대시보드 스냅샷)을 사전 아카이브해 오프라인 폴백을 둔다.

7. 운영 설계

7.1 관측 계층

현재 있는 것과 없는 것을 나눠 적는다.

계층	현재	목표
애플리케이션 지표	성립. Micrometer + Prometheus. 레코딩 룰 9, 알람 11, 대시보드 4 종. CI 가 promtool·jq 로 병합 전 검증	유지
시스템 지표	미성립(0 건)	node_exporter · cAdvisor 전 노드 배선
계층별 프로브	미성립(0 건)	blackbox_exporter 로 ICMP · TCP · HTTP 3 계층 프로브
로그	미성립. 노드별 분산	Loki + Promtail 중앙화. 실험 시각 정렬
외부 가용성	미성립	blackbox_exporter 가 외부 도메인을 30 초 주기로 프로브, probe_success 기록

계층 프로브가 이 프로젝트의 서사와 직결된다. 노드 1 대를 정지시키면 ICMP·TCP·HTTP 시계열이 서로 다른 시점에 down 으로 전이한다. 그 순서를 대시보드 1 장에서 판독할 수 있는 것이 목표이고, 이것이 "어느 계층인지 짚는다"의 실물이다.

[그림 5] 계층 판독 대시보드 구성

7.2 대시보드 4 종

대시보드	내용
01-integrity	불변식 위반 행 수, 원장 불균형, 저널 무결

02-recovery	리더 epoch 전이, RTO, 승격 이력
03-load-slo	처리량, 지연 분위, 오류율, 수용 제한 버킷
04-system	노드 자원, 컨테이너 자원, 계층 프로브 (신규 배선분 포함)

CloudFront 를 지난 사용자 관점 지표와 오리진 직접 측정 판정 지표를 같은 대시보드에 섞지 않고 분리 표기한다. 두 수치가 뒤섞이면 판정이 오염된다.

7.3 알람

Prometheus 알람 11 개가 이미 파일로 존재하고 CI 가 검증한다. 클라우드 배포 후 다음을 추가한다.

알람	임계	대응
외부 프로브 실패	`probe_success == 0` 2 분 지속	상시면 장애. 즉시 조사
오리진 인증서 만료 임박	만료 21 일 전	certbot 수동 갱신
certbot dry-run 실패	주간 실행 exit != 0	갱신 경로 점검
예산 초과	AWS Budgets 50 / 80 / 100%	12 절 감축 순서 적용
디스크 사용률	85%	저널 파티션 정리

7.4 장애 대응 절차

사용자 진술을 계층으로 좁히는 소거 절차를 문서화한다(2.5 의 표가 그 원본이다).

단계	행동	산출
1	외부 프로브 상태 확인	도달 여부
2	ICMP -> TCP -> HTTP 순으로 전이 시점 비교	후보 계층 좁힘
3	노드 자원·컨테이너 자원 확인	자원 고갈 배제
4	중앙 로그에서 해당 시각 상관 조회	오류 원문
5	필요 시 패킷 캡처(재전송·RST·SYN 재시도)	계층 확정
6	불변식 권위 run 1 회	데이터 손상 여부 판정
7	verdict 파일 아카이브	사후 증거

6 단계가 이 프로젝트의 특징이다. 복구됐다는 것과 데이터가 맞다는 것을 같은 절차 안에서 분리해 판정한다.

7.5 백업과 복구

대상	방식	주기	검증
DB 물리 백업	EBS 스냅샷	일 1 회	스냅샷에서 볼륨 복원 1 회 리허설
DB 논리 백업	pg_basebackup	주 1 회	복원 후 Flyway 버전 대조
WAL 아카이빙	archive_command 로 S3	연속	PITR 복원 리허설 1 회
복제	스트리밍 standby 1 대	연속	`pg_stat_replication` state=streaming 1 행
실험 증거	verdict JSON · DB 덤프 · 대시보드 스냅샷을 저장소 경로에 영속화	실험마다	파일 존재 확인

마지막 항목이 현재 한계를 닫는다. 카오스 볼륨이 `down -v` 로 파기되고 Write-Verdict 가 콘솔 JSON 만 내므로, 지금은 실행 이력이 저장소에 남지 않는다. 증거 영속화 배선은 감량 대상에서 제외한다.

7.6 상시성 방어

조건	결과	방어
예산 소진	인스턴스 정지 = 필수 조건 미달	AWS Budgets 3 단 알람 + Budgets Action(증명면 노드 한정)
실험이 상시면을 죽임	다운타임	파괴 실험은 증명면 전용. 상시면 실험은 kill·롤링만
오리진 전체 장애	웹은 살고 API 만 죽음	CloudFront 가 S3 오리진을 계속 서빙. 프런트에 API 장애 상태 표시
인증서 만료	502	ACM 자동 갱신 + certbot dry-run 주간 알람

상시성을 주장이 아니라 측정으로 남긴다. blackbox_exporter 의 `probe_success` 7 일 평균을 발표에서 그래프로 제시한다.

8. 보안 설계

애플리케이션 보안은 이미 구현돼 있고 코드로 대조 가능하다. 인프라 보안은 비어 있다. 남은 6 주에 새로 만드는 것은 인프라 보안이고, 애플리케이션 보안은 새로 만들지 않고 이미 있는 것을 증거 형태로 정리한다.

판정 원칙. "설정했다"는 증거가 아니다. 금지된 조작을 실제로 시도해 거부 코드가 나온 기록만 증거로 인정한다.

8.1 애플리케이션 보안 (기구현)

인증·서명 체인. API 키 인증은 6 단계를 순서 고정으로 검증한다. 순서 자체가 계약이다. 순서를 바꾸면 서명이 깨진 요청이 `nonce_used` 로 보이는 오분류가 생긴다.

단계	검증	실패 코드	방어 대상
1	JWT 구조 파싱	`jwt_verification`	형식 오염
2	HMAC-SHA256 대조	`invalid_signature`	위조·변조
3	timestamp 단방향 창	`timestamp_out_of_window`	오래된 요청 재생
4	nonce 중복 차단	`nonce_used`	동일 창 안 재전송
5	canonical(query_hash) 대조	`invalid_query_payload`	서명 후 파라미터 교체
6	scope 확인	`insufficient_scope`	권한 초과

세부 방어 장치.

장치	구현	막는 것
상수시간 비교	`MessageDigest.isEqual`	HMAC 조기 반환 타이밍 사이드채널
recvWindow 음수 클램프	`Math.max(0, ...)`	음수 recvWindow 가 하한을 반전시켜 과거 timestamp 를 무한 허용하는 경로
nonce TTL 산정	`recvWindow + CLOCK_SKEW`	허용창보다 짧은 TTL 이 만드는 재전송 창
canonical 바인딩	method + path 포함, SHA-512	같은 바디를 다른 엔드포인트로 재사용
JCS 정규화	RFC 8785	직렬화 차이로 서명·멱등키가 갈리는 것

비밀 취급.

대상	방식	설계 근거
회원 비밀번호	Argon2id + 서버 페퍼	페퍼를 접합하지 않고 `HMAC-SHA256(pepper, password)`로 고정 길이 파생 후 투입. 접합은 경계가 모호해 서로 다른 쌍이 같은 입력을 만든다
회원 세션 토큰	Ed25519 비대칭 서명	서명 길이 64 바이트 선차단으로 검증기 예외 경로 제거
API 시크릿	AES-256-GCM 봉투암호화, 저장마다 새 IV	HMAC 재계산에 복호가 필요해 비가역 해시 저장이 불가능. 마스터키 32 바이트 길이 검증

남용·자원고갈 방어.

계층	기제	특이점
수용 제한	AdmissionFilter	인증 앞단 전용 필터에 배치해 인증 연산 비용 자체를 상한 안에 둔다. 초과는 거절이 아니라 409 `requery_deferred` + Retry-After
계정 버킷	AccountRateLimiter	계약 기본 100 토큰/10s
공개 IP 버킷	PublicRateLimitFilter	계약 기본 300 토큰/10s
가입 경로	무인증 signup 에 IP 한도 + password 길이 상한	Argon2id 는 메모리 하드라 해시 단계가 그 자체로 DoS 벡터
XFF 신뢰 경계	`internal-proxies` 명시 핀	Tomcat 기본은 RFC1918 전량이라 사설 소켓피어 배포에서 클라이언트 XFF 를 채택해 IP 버킷 회전 우회가 열린다. 기본을 루프백으로 좁히고 운영은 LB VIP CIDR 만 주입. 미주입 시 fail-closed

관리 평면 격리.

항목	값
포트	8443 (고객 평면 8080 과 분리)
전송	TLS + mTLS `client-auth: need`. 인증서 없는 핸드셰이크 자체를 거부
신원 권위	클라이언트 인증서 CN. 요청 바디의 자가신고 operator_id 를 신뢰하지 않는다
헤더 우회 차단	`trusted-forwarding` 기본 false. 운영 기동에서 true 면 부팅 중단
파괴 액션	2 인 승인(approval-ttl 5m), 세션과 독립 게이트
감사	`admin_audit_log` append-only(트리거 봉쇄)

기동 시점 fail-closed. `StartupSecretValidator` 가 6 개 조건에서 기동을 중단한다. 마스터키·페퍼·세션시드 미주입, keystore 비밀번호 `changeit`, keystore 경로에 `admin-demo` 포함, `trusted-forwarding=true`. 이 여섯 조건은 그 자체가 거부 재현 증거이며, 시크릿 하나를 뺀 채 기동해 프로세스가 죽는 것을 보이면 된다. 추가 투입 0.

8.2 실사에서 나온 결함: 권한 격자가 런타임에 적용되지 않는다

이것이 보안 축의 출발점이다.

마이그레이션 14 개 중 10 개(V0·V1·V3·V4·V5·V6·V7·V9·V11·V13)가 GRANT·REVOKE 를 담는다. 원장·잔고 4 개 테이블(ledger_transactions·ledger_entries·balances·position_cost)은 `app_role` 에 SELECT 만 주고 INSERT·UPDATE·DELETE·TRUNCATE 를 명시 REVOKE 한다. 유일 쓰기 경로는 SECURITY DEFINER 함수 9 개다. PUBLIC EXECUTE 를 회수한 함수가 5 건이다.

그러나 이 격자는 현재 런타임에서 한 번도 적용된 적이 없다.

관측	근거
앱이 접속하는 DB 계정이 1 개이고 그 계정이 DB·테이블 소유자	compose 의 `SPRING_DATASOURCE_USERNAME` 이 `POSTGRES_USER` 와 동일
PostgreSQL 에서 테이블 소유자는 GRANT·REVOKE 격자를 통과하지 않는다	소유자는 암묵 전권 보유

app_role 에 GRANT 된 로그인 계정이 생성된 적 없음	V0 주석이 "실제 LOGIN 사용자는 배포 환경 프로비저닝에서 별도 생성"이라 적고, 그 프로비저닝 산출물이 없다

즉 현재 원장 직접 UPDATE 는 거부되지 않는다. 같은 종류의 결함이 이미 한 번 관측됐다. V9 마이그레이션 주석이 기록한다. operator_roles 하드 DELETE 권한 누락이 통합테스트가 슈퍼유저로 도는 탓에 배포 직전까지 숨어 있었다.

결론. 보안 축 1 순위는 새 기능 추가가 아니라 이미 설계된 권한 경계를 런타임에 실제로 켜고 그것이 작동함을 거부 코드로 증명하는 것이다. 투입 대비 증거 밀도가 가장 높고 증명 ①과 직접 결합한다.

8.3 인프라 보안 신규 작업

순위	항목	투입	핵심 증거
S1	DB 계정 권한 분리 실증	2 일	거부 재현 5 건
S2	컨테이너 하드닝	1 일	읽기전용 루트 쓰기 실패, 권한 상승 실패
S3	공급망·시크릿 스캔 CI	0.5 일	카나리아 브랜치 CI 실패 로그
S4	노출면 축소·nftables	1.5 일	외부 nmap 전후 비교
S5	SELinux enforcing 유지	1 일	AVC denial 발생과 소멸
S6	시크릿 관리	1 일	docker inspect·/proc/environ 에서 0 건
S7	TLS 종단·갱신 자동화	1.5 일	TLSv1.1 핸드셰이크 거부
S8	클라우드 네트워크 경계	1 일	프라이빗 IP 직접 접속 타임아웃
S9	호스트 접근 하드닝	0.5 일	비밀번호 인증 거부 로그

합계 10 작업일.

S1 상세. LOGIN 롤 3 개를 신설한다.

LOGIN 롤	권한	사용 주체
exchange_migrator	스키마 소유, DDL 전권, Flyway 실행	마이그레이션 잡 전용

exchange_app	app_role. 프로젝션·저널 DML. 원장 직접 DML 금지	앱 런타임
exchange_ro	harness_role. SELECT only	Grafana 데이터소스, 불변식 조회
exchange_repl	REPLICATION	standby

동시에 앱의 spring.flyway.enabled 를 prod 에서 false 로 내리고 마이그레이션을 별도 1 회성 잡으로 분리한다. 현행은 api-1 이 마이그레이션을 겸하고 api-2 는 순서에 의존하는데, 다중 노드 롤링 배포에서 이 순서 의존이 깨진다.

거부 재현 표. 서로 다른 기제가 서로 다른 코드로 거부한다는 점이 핵심이다.

시도	기대 결과	거부 기제
UPDATE ledger_entries SET amount = amount + 1000000	42501 permission denied	GRANT 격자
UPDATE command_journal SET payload = '{}'	P0001 트리거 EXCEPTION	forbid_mutation ROW·STATEMENT
DROP TABLE trades	42501 must be owner	소유권 분리
SET ROLE exchange_migrator	permission denied to set role	롤 멤버십 분리
rebuild_position_cost 호출	42501	함수 EXECUTE 미부여

S4 상세. 카오스 스택이 호스트에 공개하는 포트가 현재 7 개다(55432 PostgreSQL, 58474 Toxiproxy admin, 18080·28080 app 직결, 58080 nginx, 59090 Prometheus, 53001 Grafana). Toxiproxy admin API 는 인증이 없는 장애 주입 API 다. 목표는 443 단독이다.

여기서 발표에 쓸 실패가 하나 나온다. firewalld 에서 55432 를 막아도 외부에서 계속 접속된다. Docker 의 공개 포트가 nat PREROUTING 의 DNAT 를 거쳐 FORWARD 체인으로 흐르는데 firewalld 존 정책은 INPUT 체인에 적용되기 때문이다. 방화벽이 컨테이너 공개 포트를 막지 못한다. 올바른 조치는 규칙 추가가 아니라 ports: 바인딩 축소다. 이 진단은 이 프로젝트의 명제(계층을 짚는다)와 정확히 같은 형태다.

8.4 하지 않는 것과 사유

항목	사유
침투 테스트·퍼징	이 축은 방어 설정의 실증이지 공격 내성 증명이 아니다. 6 주에 유의미한 공격 커버리지가 나오지 않는다

OWASP Top 10 전수 점검	동상. 대신 각 조치가 막는 구체 시나리오 1 개씩만 적는다
STRIDE 위협 모델 문서	문서만 늘고 실증 증거가 나오지 않는다
마스터키 회전	재암호화 잡이 없다. 유출 시 대응은 전면 재발급뿐이며 이를 한계로 적는다
NonceStore Redis 전환	13 절 참조. 보안 개선 하나가 HA 판정 설계와 부하 오류율 예산을 동시에 건드린다
WAF	비용·운영 부담 대비 나올 증거가 얇다
RLS	단일 테넌트라 테이블 단위 권한으로 충분하고, SECURITY DEFINER 함수와 정책이 충돌한다

9. 비용 산정

9.1 산정 원칙

비용은 결과가 아니라 설계 변수로 다룬다. 상한을 먼저 정하고 그 안에 들어오는 토폴로지를 고른다.

항목	값
상한	월 100,000 원(VAT 포함). 초과하면 설계를 고친다
단가 원천	AWS Price List Bulk API 서울 리전 오퍼 파일, 판본 20260824193147(발행 2026-08-24). 블로그·요약 사이트 수치는 쓰지 않는다
시간 기준	월 730 시간
환율	1 USD = 1,400 원. 1,350·1,450·1,500 원 민감도 병기
부가세	사업자등록번호 없는 개인 고객에게 10% 청구. 모든 총계에 가산
크레딧	0 으로 가정. 크레딧은 여유이지 전제가 아니다

3 자 사이트가 서울 t3.medium 을 절반 값으로 적은 사례를 실제로 확인했으므로 원천을 공식 요금표로 고정했다.

9.2 서울 리전 단가 (2026-08-24 판)

항목	단가
t4g.micro (2 vCPU / 1 GiB)	USD 0.0104 /hr
t4g.small (2 / 2 GiB)	USD 0.0208 /hr
t4g.medium (2 / 4 GiB)	USD 0.0416 /hr
c7g.large (2 / 4 GiB, 비버스터블)	USD 0.0816 /hr
t3.medium (2 / 4 GiB)	USD 0.0520 /hr
EBS gp3	USD 0.0912 /GB-월
EBS 스냅샷	USD 0.0500 /GB-월
퍼블릭 IPv4	USD 0.0050 /hr (사용 여부 무관)
인터넷 아웃바운드	USD 0.126 /GB
NAT Gateway	USD 0.059 /hr + USD 0.059 /GB
ALB	USD 0.0225 /hr + USD 0.008 /LCU-hr
Route 53 호스팅 영역	USD 0.50 /월
CloudWatch 로그 수집	USD 0.76 /GB
RDS db.t4g.small Multi-AZ	USD 0.102 /hr

9.3 프리티어 적용 범위

2025-07-15 이후 개설 계정은 12 개월 프리티어 대상이 아니다. 가입 크레딧 USD 100, 활동 수행 시 최대 100 추가, 무료 요금제는 6 개월 또는 크레딧 소진 중 이른 쪽에서 종료된다.

항목	산정 반영
CloudFront 아웃바운드 1TB/월, 요청 1,000 만/월	적용. 정적 export 6.3MB 규모는 전량 한도 안
CloudWatch 알람 10 개·지표 10 개·로그 5GB	적용
S3 5GB·GET 2 만·PUT 2 천	적용
EC2 750 시간 t3.micro	미적용으로 계상. 신규 계정 대상이 아니고, 적용돼도 1 GiB 는 이 스택 최소 요건 미달이라 설계를 바꾸지 않는다
인터넷 아웃바운드 100GB/월	미적용으로 계상. 보수적으로 전액 과금 처리
EBS·EIP·Route 53	프리티어 항목 아님. 전액 과금

무료 요금제가 아니라 유료 요금제를 선택한다. 사유 셋. 무료 요금제는 서비스 접근이 제한돼 필요 리소스 생성 가능 여부가 불확실하다. 6 개월 종료 후 계정이 닫히고 데이터는 90 일만 보존되므로 발표 후 포트폴리오 유지가 불가능하다. 유료 요금제에서도 크레딧은 동일 지급되고 이후 청구서에 자동 적용된다.

9.4 상시면 월 비용

상시면 구성은 edge(t4g.micro) + core(t4g.medium) + S3·CloudFront 다. 퍼블릭 IPv4 는 edge 1 개만 붙이고 core 는 프라이빗 서브넷에 두어 edge 의 nftables masquerade 로 아웃바운드를 낸다.

항목	산정식	USD	원(1,400)
EC2 edge t4g.micro	0.0104 x 730	7.59	10,629
EC2 core t4g.medium	0.0416 x 730	30.37	42,515
EBS gp3 40 GiB	40 x 0.0912	3.65	5,107
퍼블릭 IPv4 1 개	0.005 x 730	3.65	5,110
EBS 스냅샷 12 GiB	12 x 0.05	0.60	840
Route 53 영역 + 질의 20 만	0.50 + 0.08	0.58	812
S3 저장 + 요청		0.14	196
CloudFront	프리티어 한도 안	0.00	0
인터넷 아웃바운드 20GB (추정)	20 x 0.126	2.52	3,528
소계		49.10	68,737
부가세 10%		4.91	6,874
합계		54.01	75,611

아웃바운드 20GB 는 추정이다. 실측하지 않았다.

9.5 상시 구동 대 필요시 구동

증명면 4 노드(app-2 c7g.large, pg-standby t4g.small, obs t4g.medium, load c7g.large)의 시간당 합계는 USD 0.2256 이다.

가동시간	USD (VAT 별도)	USD (VAT 포함)	원(1,400)

20 시간	4.51	4.96	6,948
40 시간	9.02	9.93	13,897
65 시간 (계획값)	14.66	16.13	22,583
100 시간	22.56	24.82	34,742
730 시간 (상시)	164.69	181.16	253,620

차액 USD 165.03(약 231,000 원), 11.2 배. 증명면을 상시로 두면 그것만으로 월 상한을 두 배 반 넘긴다.

65 시간의 근거(추정). 검증 창 주 2 회 x 3 시간 = 21 시간, soak 2 시간 x 3 회 = 6 시간, k6 부하 회차 8 시간, 배선 시험 6 시간, 리허설 4 회 x 2.5 시간 = 10 시간, 발표 당일 4 시간. 합 55 시간에 15% 여유를 붙였다.

정지(stop)는 무료가 아니다. 인스턴스를 정지해도 EBS 루트 볼륨은 계속 과금된다.

운용 방식	상주 용량	월 USD	원
stop 운용	106 GiB gp3	9.67	13,534
terminate + AMI 운용	25 GiB 스냅샷	1.25	1,750
차		8.42	11,784

증명면은 정지하지 않고 파기한다. AMI 에서 매 회차 생성하고 회차가 끝나면 볼륨까지 지운다. 비용 절감이면서 동시에 빈 환경 콜드 스타트를 매 회차 강제 검증하는 효과가 있다.

9.6 버스터블 크레딧 초과 위험과 제거

T 계열은 기본이 Unlimited 모드다. 크레딧을 다 쓰면 초과분을 과금한다(서울 t4g USD 0.04/vCPU-시간). t4g.medium 1 대가 한 달 내내 CPU 100%면 최악값이 USD 46.72 로, 인스턴스 요금 USD 30.37 보다 크다. soak 2 시간 같은 지속 부하 구간이 정확히 이 조건이다.

대상	조치	결과
상시면 edge·core	`--cpu-credits standard`	크레딧 소진 시 베이스라인 스로틀. 초과 과금 구조적으로 0
증명면 app-2·load	비버스터블 c7g.large 고정	초과 과금 0. 크레딧 고갈로 인한 성능 변동이 RTO 측정에 섞이지 않는다
증명면 pg-standby·obs	standard 모드	초과 과금 0

지속 부하 아래 Unlimited t4g.medium 의 실효 단가는 최대 USD 0.1056/시간이라 오히려 c7g.large(0.0816)가 싸다. 측정 유효성과 비용이 같은 방향을 가리킨다.

9.7 6 주 총 비용

발표까지(2026-09-01 ~ 10-16, 46 일, 상시 1,104 시간).

항목	USD	원(1,400)
상시 EC2 2 대	57.41	80,371
퍼블릭 IPv4	5.52	7,728
상시 EBS 40 GiB	5.52	7,728
스냅샷·AMI 37 GiB	2.80	3,919
Route 53	0.88	1,229
S3 + CloudFront	0.21	297
인터넷 아웃바운드	3.81	5,338
증명면 65 시간	14.66	20,530
소계	90.81	127,140
부가세 10%	9.08	12,714
총계	99.90	139,854
월 환산 (46 일 = 1.513 개월)	66.02	92,425

환율 민감도.

환율	6 주 총계	월 환산	상한 대비 여유
1,350 원	134,859 원	89,124 원	10.9%
1,400 원	139,854 원	92,425 원	7.6%
1,450 원	144,848 원	95,726 원	4.3%
1,500 원	149,843 원	99,027 원	1.0%

9.8 비용을 줄이는 설계 선택

관리형 3 종을 쓰지 않는다. 월 USD 97.43 회피.

대상	관리형 월	대체	대체 월	차
ALB	22.27	edge 노드 nginx	0	22.27
NAT Gateway	43.07	edge 노드 nftables masquerade	0	43.07
RDS Multi-AZ + gp3 40GB	84.94	EC2 2 대 자체 복제 + 80 GiB	52.85	32.09

이것은 비용 회피가 아니라 과제 그 자체다. RDS Multi-AZ 는 페일오버 내부가 닫혀 있어 복제 링크에 tc netem 을 걸 수 없고 승격 로그도 볼 수 없다. 증명 ②의 판정 대상이 사람 개입 없는 승격인 이상 승격 주체가 내 손 안에 있어야 한다. ALB 도 같다. 능동 헬스체크를 붙이는 것이 이 프로젝트의 잔여 과제인데, 관리형을 쓰면 그 과제가 사라지는 것이 아니라 관측 불가능해진다.

관측을 관리형에 올리지 않는다. 월 USD 189.57 대안 비용 회피.

항목	산정식	USD / 월
커스텀 지표 500 종 (추정)	500 x 0.30	150.00
로그 50GB 수집 + 보관	50 x (0.76 + 0.0314)	39.57
알람 11 개 중 무료 10 개 초과	1 x 0.10	0.10

대체 비용은 상시면 core 노드 겸용이라 증분 0 원, 증명 창에서 obs 분리 노드 USD 2.70 이다. 지표 500 종은 추정이며 배포 직후 `/actuator/prometheus` 계수로 확정한다. 시계열이 절반이어도 회피액은 월 USD 114.57 로 결론의 부호는 바뀌지 않는다.

Graviton 채택으로 상시면 월 USD 9.49(20%) 절감. 앱 이미지 베이스가 멀티아키텍처이고 app.jar 가 아키텍처 중립이지만 arm64 태그 실물 pull 검증은 하지 않았다.

9.9 채택하지 않은 선택지

선택지	이론상 절감	거절 사유
스팟 인스턴스	60~70%	실험 중 AWS 회수와 내가 주입한 장애를 구분할 수 없다. 증명 ②의 판정이 오염된다
Reserved / Savings Plans	30~40%	최소 약정 1 년. 프로젝트 기간 6 주

미국 리전 배치	EC2 20%, 아웃바운드 29%	왕복 150ms 이상이 RTO 측정에 잡음으로 섞인다
IPv6 전용	월 USD 3.65	심사자 접속 경로의 IPv6 지원 여부를 통제할 수 없다
무료 요금제 계정	6 개월 무과금	서비스 접근 제한과 6 개월 후 계정 폐쇄

9.10 초과 방지 장치와 감축 순서

단일 장치에 의존하지 않는다.

계층	장치	동작
예방	IAM 권한 경계로 인스턴스 타입 화이트리스트	비허용 타입 실행 거부
예방	IAM Deny: 타 리전 전면 거부	리전 밖 리소스 생성 차단
예방	IAM Deny: NAT Gateway·ALB 생성 금지	고정비 관리형 2 종을 실수로 만들 수 없다
예방	OIDC 역할 사용, 장기 액세스 키 0 개. gitleaks CI 배선	키 유출 경유 채굴 과금 차단
자가	user-data `shutdown -h +240` + shutdown behavior terminate + DeleteOnTermination	켜 둔 채 잊어도 4 시간 뒤 자멸. AWS 서비스에 의존하지 않는다
자동	EventBridge -> Lambda 로 매일 03:00 KST `Lifecycle=ephemeral` 종료	잔존 노드 회수
감지	AWS Budgets 월 USD 70, 크레딧 제외 기준, 50/80/100% + 예측 100%	크레딧이 남아도 실비 런레이트가 보인다
감지	Cost Anomaly Detection, CloudWatch 결제 알람	이상치 통보
강제	Budgets Action: 100% 도달 시 `Lifecycle=ephemeral` 노드만 정지	상시면은 대상 제외. 예산 대응으로 서비스를 죽이면 학교 요건을 스스로 깬다

사후	비용 배분 태그 Project·Env·Lifecycle, Cost Explorer 주 1 회	어느 축이 돈을 쓰는지 분해

감축 순서를 미리 확정한다. 실행 시점에 판단하지 않는다.

순위	조치	월 절감	잃는 것
1	증명면 65 시간 -> 40 시간	7,896 원	실험 회차 수. 로컬 랩에서 흡수
2	상시면 봇 OPS 하향 + 유휴 시 pause	2,114 원	방문자가 보는 체결 빈도
3	edge 노드 정지, nginx 를 core 로 이전	12,824 원	TLS·NAT·프로브 분리 구조
4	core EBS 32 -> 24 GiB	1,022 원	soak 데이터 보존 기간
5	정적 웹만 남기고 상시 API 정지	42,515 원	최후 수단. 학교 필수 요건을 깨므로 실행하지 않는다

1~4 번을 모두 실행하면 월 환산 92,425 원이 75,569 원이 되어 환율 1,500 원 구간에서도 상한 안에 들어온다.

10. 검증 계획

10.1 장애 실험 매트릭스

실험 9 종이 오케스트레이터로 배선돼 있다(스크립트 12 파일 2,413 줄, 실험별 env 9 개).

ID	실험	주입	현재 상태
E1	PG 지연	Toxiproxy 200/100ms	라이브 PASS. errorRate 0, 복구 2.06 초, 두 버킷 포화에서 노드 생존
E2	PG 단절·블랙홀	커넥션 절단	라이브 PASS. RTO 13.882 초, 재실행 14.367 초, epoch 1 -> 2

E3	Redis 정지	해당 없음	SKIP 이 유효 판정
E4	리더 kill	`docker kill`	배선 완료. 현 술어 기준 실측 미확인
E5	네트워크 분단	네트워크 분리	라이브 PASS. RTO 11.99 초, 리더 교체, 체결 35,070 -> 36,257
E6	스파이크 + 페일오버	400 ops + kill	라이브 PASS. RTO 0.107 초
E7	그레이 장애	`docker pause`	라이브 PASS. RTO 9.983 초, 좀비 stale 0
E8	앱 내부 assault	Chaos Monkey	배선 완료, 라이브 PASS 미기록
E9	커밋 경로 단절	커밋 시점 절단	라이브 PASS(판정기 교정 이전, 등급 낮음)
E10	tc netem 커널 큐 주입	지연·유실·재정렬·대역폭	신규. 남은 기간 목표

E5·E7 두 실험 모두 C01~C23 전건 0 위반이었다. 복구됐다는 사실과 데이터가 맞다는 사실을 같은 실행 안에서 함께 판정했다.

E3 는 미완이 아니다. 스크립트 헤더가 Redisson 미배선(redis·redisson·lettuce·jedis 의존 0 건, spring.data.redis 설정 0 건, compose 에 redis 서비스 0 건)을 근거로 SKIP 을 유효 판정으로 규정한다. 리더십 권위가 DB leader_lease 이므로 Redis 장애가 매칭·리더십·split-brain 에 도달할 경로 자체가 없다. 스크립트는 SKIP 경로에서도 leader_lease holder·lease_alive 를 읽고 권위 run 1 회를 돌려 "Redis 없이 DB 권위 리더십이 성립"을 증거로 남긴다.

E4 RTO 는 이 계획서에 수치로 적지 않는다. 2026-08-18 에 RTO 측정 술어가 이벤트 축에서 명령 축으로 교체됐고 그 이후 재측정 기록이 없다. 증명 ②의 대표 수치이므로 재실행으로 확정한 뒤에만 인용한다. 이 재실행이 남은 일 1 순위다.

10.2 RTO 정의

페일오버 후 최초 신규 TRADE 의 engine_ts(T5)에서 kill 시각(T0)을 뺀 값이다. T5 술어는 명령 축 fencing 기준(`command_journal.fencing_token > 구 epoch`)으로 확정됐다. 이벤트 축 술어와 승격 워터마크 술어는

승격 재생 산출물을 재개로 오인해 RTO 를 과소 보고하므로 폐기됐다(E6 동일 조건 실측 0.086 초 대 10.698 초).

판정 프로토콜. 사전 권위 run(불변식 green) -> 주입 -> 무개입 관찰 -> 사후 권위 run.

10.3 계층 판정 (신규)

이 축이 이 프로젝트의 핵심 서사이면서 현재 완전히 비어 있다.

항목	현재	목표	판정
ICMP·TCP·HTTP 프로브	0 건	blackbox_exporter 3 계층	노드 1 대 정지 시 세 시계열이 서로 다른 시점에 down 으로 전이하고 대시보드 1 장에서 순서 판독
시스템 지표	0 건	node_exporter · cAdvisor	노드·컨테이너 자원이 실험 구간에 정렬돼 보인다
커널 계층 주입	없음(Toxiproxy 는 프록시 레벨)	tc netem 지연·유실·재정렬·대역폭	E10 판정 스크립트 exit 0, 불변식 위반 0 행
패킷 근거	미사용	tcpdump 캡처	재전송 또는 RST 를 근거로 원인 계층 지목
로그 상관	노드별 분산	Loki + Promtail	4 노드 로그가 단일 Grafana 쿼리로 조회

Toxiproxy 와 tc netem 의 차이를 발표에서 흐리지 않는다. Toxiproxy 는 프록시 레벨 주입이라 커널 큐 거동을 재현하지 않는다. 지금까지의 네트워크 분단 실험은 전부 모사이고 실제 파티션이 아니다.

10.4 불변식

앱 검증기(InvariantCheck enum)가 배선한 체크는 26 개다. C04 는 enum 밖이고 DEFERRED CONSTRAINT TRIGGER 가 하드 강제한다. SQL 판정 카탈로그 harness/sql/invariants.sql(235 줄)은 C04 포함 27 개 ID 를 다룬다.

등재 목록. C01, C02, C03, C05, C06, C07, C07P, C08, C09, C10, C11, C12, C13A, C13B, C14, C15, C16, C17, C18, C19, C20, C21, C22, C23, C24, C25.

Scope 가 두 축이라 혼동하기 쉽다. 분리해 적는다.

축	대상
서버측 `AUTHORITATIVE_ONLY` (상시 스케줄 제외, 권위 run 에서만 평가)	C13A, C16, C19, C22, C23, C24, C25 (7 종)
하네스측 라이브 게이팅 면제	C13A, C16, C19 (3 종). C22·C23 은 게이팅에서 빼지 않는다

상시 스캔은 InvariantScheduler 가 5 분 fixedDelay 로 리더 노드에서만 돈다.

검증기 반증. InvariantVerifierIntegrationTest 가 @Test 14 개이고 그중 위반 고의 주입·검출이 8 건 이상이다. C16 은 CI 경로에서 공허 통과가 아니다. 같은 테스트가 봇 NEW 명령을 harness.loadtest_acks 에 실적재해 조인을 실데이터로 평가하고, 미저널 ACK 1 건을 고의 주입해 pass=false 로 떨어지는지까지 음성 검증한다.

10.5 부하

현재 자산은 실재하나 실행 배선이 0 건이다. order_flow.js 305 줄(orders_steady·orders_spike·market_reads·ws_stomp 4 시나리오 + thresholds), thundering-herd.js 66 줄, sign.js 59 줄, stomp.js 56 줄(k6/websockets 위 STOMP 1.2 직접 구현). 워크플로 3 종 어디에도 k6 문자열이 없고, 카오스 스크립트 9 종 어디에도 k6 호출이 없으며, compose 에도 k6 서비스가 없다.

단계	내용	판정
B1 실행 배선	compose 서비스 + 스크립트 호출 + thresholds exit code	스크립트가 k6 를 호출하고 thresholds 위반 시 exit code 0 이 아님
B2 부하 3 종 실행	정상, 스파이크, 페일오버 중 부하	각 회차 결과를 파일로 기록

이 배선이 없으면 "0 행 = 무결" 주장이 "0 행 = 아무 일도 안 일어남"과 구분되지 않는다. 현재 부하 원천은 봇 플릿뿐이고, E5 의 체결 증분(35,070 -> 36,257) 같은 활성 근거는 있으나 정량적 부하 프로파일이 아니다. k6 실행 배선을 감량 불가 항목에 넣은 이유가 이것이다.

10.6 증거 등급과 보존

등급	정의	예

E-A 거부·주입 재현	금지된 조작을 실제 실행해 거부 코드를 획득	42501, P0001, 핸드셰이크 거부
E-B 상태 덤프	적용된 설정을 기계 판독 형식으로 추출	`nft list ruleset`, `docker inspect`, `\dp`
E-C 외부 스캔	외부 관점 도구 리포트와 exit code	nmap, Trivy, gitleaks
E-D 자동화 실행 로그	갱신·배포 자동화 실제 실행 기록	`certbot renew --dry-run`, systemd timer

현재 카오스 실험 판정 산출물이 저장소에 남지 않는다. Write-Verdict 는 콘솔 JSON 만 출력하고, 페일오버 판정은 컨테이너 안 harness.failover_runs 에 적재돼 `down -v` 로 파기된다. 실험마다 verdict JSON·DB 덤프·대시보드 스냅샷을 저장소 경로에 남기는 배선을 W2 에 넣는다.

10.7 CI 게이트

워크플로	잡·스텝
ci-backend.yml	build-test(Temurin 21, gradlew build, Testcontainers) + observability(promtool check config·rules, jq 기반 대시보드 panels 검증)
ci-web.yml	Node 22 핀, npm ci, npm run build, 정적 export 산출물 검증, tsc --noEmit, npm test
style.yml	산출물 스타일 게이트
security.yml (신규)	gitleaks 전 히스토리, Trivy 이미지·config, npm audit. 카나리아 브랜치로 스캐너 작동 자체를 증명
image.yml (신규)	GHCR 이미지 빌드·푸시
deploy.yml (신규)	웹·앱 배포, 수동 승인 환경

11. 일정

11.1 기간과 가용 시간

기준일 2026-08-25(화). 계획서 제출 2026-09-01(화) 12:00. 최종 발표 2026-10-16(금).

구분	값
전체 기간	53 일 (2026-08-25 ~ 2026-10-16)
수업일	34 일 (평일 39 일에서 공휴일 5 일 제외)
휴일	19 일 (주말 14 + 평일 공휴일 5)

기간 중 공휴일은 09-24, 09-25, 09-28, 10-05, 10-09 다. 전업 수행이므로 공휴일은 작업일 수를 줄이지 않고 수업 유무만 바꾼다. 연휴 구간은 가용 시간이 오히려 늘어난다.

일 유형	일수	유효 시간/일	소계
수업일	34	6h	204h
휴일	19	9h	171h
총 가용	53		375h
의도적 휴식 4 일		-9h	-36h
09-01 반일		-3h	-3h
순 가용			336h (42.0 인일)

수업일 6 시간은 보수 추정이고 검증되지 않은 가정이다. 09-02 ~ 09-04 사흘간 실 작업 시간을 기록해 09-04(금)에 재캘리브레이션한다. 실측이 5h 미만이면 전체 예산을 재산정하고 감량 순위 1~3 을 선제 적용한다.

의도적 휴식 4 일은 낭비가 아니라 계획 항목이다. 53 일 연속 무휴 계획은 후반부 판단력 저하로 회수되고, 그 회수 시점이 하필 코드 동결 직전이다.

11.2 고정점

고정점	일자	침범 불가 사유
계획서·PPT 제출	2026-09-01(화) 12:00	학교 제출 기한
클라우드 외부 접속 성립	2026-09-08(화)	학교 필수 조건. 여기서 막히면 남은 전 계획의 전제가 깨진다
1 차 코드 동결(기능 동결)	2026-10-09(금) 18:00	발표 준비 7 일 확보선
2 차 전면 동결 + 태깅	2026-10-13(화) 24:00	리허설 대상 고정
최종 발표	2026-10-16(금)	학교 지정

11.3 주차별 계획

주차	기간	순 가용	주제	완료 정의(DoD)
W0	08-25 ~ 09-01	51h	계획서 제출 + 실행 환경 이설	팀즈 업로드 완료. VM 에서 `docker compose up -d --wait` 성공, 상시 6 서비스 healthy. `git status` 클린
W1	09-02 ~ 09-08	48h	클라우드 착지 + 방화벽	공인 도메인 HTTPS 로 웹 200, `GET /api/v1/markets` 200. nftables 적용 상태에서 지정 포트 외 인바운드 전부 차단(외부 nmap 확인). `getenforce` 가 Enforcing
W2	09-09 ~ 09-15	48h	관측 하단 채우기	노드 1 대 정지 시 ICMP·TCP·HTTP 시계열이 서로 다른 시점에 down 으로 전이하고 순서 판독 가능. 4 노드 로그가 단일 쿼리로 조회. 실험 1 회가 verdict 파일을 남김
W3	09-16 ~ 09-22	39h	부하 실측 배선 + LB 분산	k6 thresholds 위반 시 exit code 0 아님. 조회 트래픽이 두 노드에 분산(어느 쪽도 90% 초과 안 함). 쓰기는 리더 단독
W4	09-23 ~ 09-29	39h	DB 이중화 + 권한	`pg_stat_replication`

			분리	state=streaming 1 행. primary 정지 후 승격 절차로 서비스 재개, 손실 트랜잭션 수와 소요 시간 실측 기록. 앱 런타임 롤로 DDL 시도 시 42501
W5	09-30 ~ 10-06	51h	실 네트워크 장애 + 배포 자동화 + 흡수	tc netem 지연·유실 하에서 E10 exit 0, 불변식 0 행. tcpdump 캡처에서 재전송 또는 RST 로 원인 계층 지목. main 푸시부터 배포 완료까지 체결 정지 0 초
W6	10-07 ~ 10-09	21h	최종 증명 완주, 코드 동결	클라우드 스택에서 E1·E2·E4·E5·E6·E7·E8·E10 순차 실행, 전건 verdict 파일 산출. 자산합 위반 0 행, 중복·유실 0. E4 RTO 30 초 이내 실측
W7	10-10 ~ 10-16	39h	발표 준비, 리허설	리허설 3 회 완료, 각 회차 15 분 이내. 데모 폴백(녹화본) 준비. 태그 v1.0.0

주차 경계를 화요일 밤에 둔다. 매주 화요일 22:00 에 DoD 를 이진 판정하고 다음 주 착수 전에 감량 여부를 결정한다. 부분 달성은 미달로 계상한다.

11.4 작업 항목과 소요

ID	항목	소요	배치
E1	AWS VPC·서브넷·SG·EC2	12h	W1

	프로비저닝, docker 설치		
E2	도메인·DNS, Let's Encrypt TLS 종단, nginx 443	8h	W1
E3	웹 정적 export 배포 + API 오리진 연결	8h	W1
F1	nftables 정책 설계·적용, firewalld·SELinux 증빙	12h	W1
A1	node_exporter + cAdvisor 배선	4h	W2
A2	blackbox 3 계층 프로브, 알람 룰, 계층 판독 대시보드	16h	W2
A3	Loki + Promtail 로그 중앙화	12h	W2
H1	실험 판정 산출물 파일 영속화	8h	W2
B1	k6 실행 배선	12h	W3
B2	부하 3 종 실행·기록	8h	W3
G1	리더 인지 LB 라우팅	12h	W3
D1	PostgreSQL 스트리밍 복제, 수동 승격 실측	16h	W4
F2	DB 롤 분리	8h	W4
F3	시크릿 분리, 보안 헤더	6h	W4
C1	tc netem 주입 배선 + E10 신규 실험	12h	W5
C2	tcpdump 계층 지목 증거	4h	W5
G2	배포 자동화(GHCR + 롤링)	8h	W5
H3	soak 2 시간 무인 실행	4h	W5
H2	클라우드 스택 전 실험 완주	16h	W6
	계획 작업 소계	186h	

	예비(슬랙)	60h	
	구현 구간 합계	246h	

스트레치 항목은 기본 계획에 넣지 않는다. 예비 잔량 조건을 충족할 때만 착수한다. Patroni + etcd 자동 승격 24h(W4 종료 시 잔량 30h 이상), Terraform 코드화 16h(W5 종료 시 20h 이상), 비용 대시보드 8h(W5 종료 시 10h 이상).

11.5 예비일 운영

이 저장소에는 환경 마찰 5 종(한글 경로 Gradle 파손, pwsh7 미설치 BOM 파싱 실패, `down -v` 볼륨 미삭제, 공유 .next 손상, Docker VM 시계 비단조성)이 문서화돼 있다. 판정 경로 추적 한 번이 2~3 일을 먹은 전례가 7 건이다. 슬랙 0 계획은 이 저장소에서는 실패가 확정돼 있다.

종류	규모	위치	운영 규칙
주간 슬랙	주당 5 ~ 9h	W0 ~ W4, W6, W7	해당 주 안에서만 소진. 이월하지 않는다
연휴 흡수 블록	27h	10-03 ~ 10-05	코드 동결 4 일 전 마지막 흡수 지점
추석 여유	9h	09-24 ~ 09-28	긴 블록이 필요한 DB 복제를 여기 배치

소진 규칙. 예비는 신규 항목 착수에 쓰지 않고 계획 항목의 초과분 흡수에만 쓴다. 한 항목이 추정의 1.5 배를 넘기면 즉시 중단하고 화요일 판정까지 보류한다. 주간 슬랙이 0 이 된 주는 그 주에 감량 1 단계를 적용한다. 연휴 흡수 블록을 쓰기 시작한 시점에 스트레치 3 종은 전부 폐기한다.

장애 유형별 대응 시한. 환경 마찰 4h, 판정 경로 의심 8h(판정기부터 검사한다. 과거 7 건 중 다수가 서버가 아니라 판정 경로 결함이었다), 클라우드 계정·과금·쿼터 2h.

11.6 코드 동결

단계	일시	허용	금지
1 차 (기능 동결)	10-09(금) 18:00	문서, 발표 자료, 데모 데이터 리셋, 데모 차단	신규 기능, 신규 실험, 리팩터링, 의존성 버전 변경

		결함 hotfix	
2 차 (전면 동결)	10-13(화) 24:00	없음	전부. 태그 v1.0.0 부착 후 브랜치 보호

hotfix 예외는 데모 시나리오를 실행 불가로 만드는 결함에 한한다. 변경 후 전 실험 재실행은 요구하지 않고 스모크 1 회와 불변식 권위 run 1 회만 요구한다.

11.7 감량 순서

밀린 뒤에 무엇을 자를지 고민하면 늦다. 위에서부터 자른다.

순위	자를 항목	대체	잃는 것
1	soak 2 시간	30 분 축소본	장기 누수·드리프트 관측
2	로그 중앙화	`docker compose logs` 수집 스크립트 + 파일 아카이브	실시간 상관 조회. 사후 조회는 유지
3	tcpdump 증거	수동 캡처 1 회, 자동화 포기	재현 가능한 패킷 근거
4	배포 자동화	수동 배포 스크립트	무중단 배포 실증. 배포 자체는 됨
5	시크릿 관리	파일 분리까지만, 보안 헤더 생략	헤더 축
6	부하 3 종	1 종(정상)만 실행	스파이크·페일오버 중 부하 수치
7	DB 복제	복제 구성까지만, 승격 미측정	RPO 실측
8	리더 인지 LB	현행 backup 정적 승계 유지	평시 분산. 약 1.25% POST 실패 바닥 존치

절대 자르지 않는 항목. 클라우드 배포 3 종(학교 필수 조건), nftables·SELinux(보안 축의 유일한 실물 근거), 시스템 지표와 계층 프로브(지도교수 지침의 핵심), k6 실행 배선(이것 없이 부하 축을 주장하면 과장이 된다), 증거 파일 영속화(심사에서 증명할 수 없다), 최종 완주, 발표 준비 7 일.

12. 완료 기준

전부 기계 판정한다. "된 것 같다"는 판정하지 않는다.

12.1 증명 명제

#	기준	판정 방법
P1	증명 ① 체결 무결	클라우드 스택에서 부하 + 장애 주입 하에 불변식 26 개 위반 행 수 0
P2	증명 ② 자동 복구	E4 RTO 30 초 이내, epoch 정확히 +1, 수동 개입 0 회
P3	판정기 신뢰성	반증 테스트 8 건 이상이 위반 주입 시 pass=false 로 떨어진다

12.2 배포·인프라

#	기준	판정 방법
D1	외부 도메인 HTTPS 접속	외부 회선에서 `curl -sI https://<도메인>` 첫 줄 200
D2	웹이 실서버 데이터 표시	배포 번들에 `NEXT_PUBLIC_DATASOURCE=http` 인라인 확인 + `/api/v1/markets` 200 + 화면 시세 갱신
D3	WS 실시간 수신	`wss://<도메인>/ws/v1` 연결 후 60 초간 `/topic/trade.KRW-BTC` 프레임 1 건 이상
D4	무중단 롤링 배포	롤링 전 구간 k6 `orders_steady` 에러율 0, 사후 불변식 0 행, RTO 30 초 이내
D5	TLS 종단	엣지·오리진 모두 TLS 1.2 이상, TLSv1.1 핸드셰이크 거부. `certbot renew --dry-run` exit 0
D6	오리진 우회 차단	오리진 퍼블릭 IP 직접 HTTPS 요청

		시 관리자 IP 외에서 타임아웃
D7	DB 권한 분리	앱 계정으로 DDL·원장 직접 DML 시도 시 42501, 저널 UPDATE 시 P0001
D8	상시성	blackbox `probe_success` 7 일 평균 0.99 이상
D9	시크릿 미하드코딩	gitleaks 0 건. 노드에서 `docker inspect` 로 평문 시크릿 0 건

12.3 관측·검증

#	기준	판정 방법
V1	계층 판독	노드 1 대 정지 시 ICMP·TCP·HTTP 세 시계열의 down 전이 시점이 서로 다르고 대시보드 1 장에서 순서 판독
V2	커널 계층 주입	tc netem 하에서 E10 판정 스크립트 exit 0, 불변식 위반 0 행
V3	패킷 근거	tcpdump 캡처에서 재전송 또는 RST 를 근거로 원인 계층 지목
V4	로그 중앙화	4 노드 로그가 단일 Grafana 쿼리로 조회
V5	부하 실측	k6 thresholds 위반 시 exit code 0 아님. 3 종 회차 결과 파일 존재
V6	부하 분산	조회 트래픽의 노드별 분배에서 어느 쪽도 90% 초과하지 않음
V7	DB 복제	`pg_stat_replication` state=streaming 1 행. 승격 후 손실 트랜잭션 수와 소요 시간 실측 기록
V8	증거 영속화	클라우드 최종 완주 8 실험 전건 verdict 파일이 저장소 경로에 존재

12.4 비용

#	기준	판정 방법
B1	월 환산 실비 100,000 원 이하	AWS 청구서(부가세 포함)
B2	예산 초과 방지 장치 작동	Budgets 알람 수신 이력, 자가 종료 인스턴스의 terminate 로그
B3	장기 액세스 키 0 개	IAM 액세스 키 목록 비어 있음

12.5 발표

#	기준
R1	리허설 3 회 완료, 각 회차 15 분 이내
R2	데모 폴백(전 구간 녹화본) 확보
R3	태그 v1.0.0 부착

13. 한계와 리스크

안 한 것을 안 했다고 이름으로 적는다. 심사에서 물으면 그대로 답할 내용이다.

13.1 현재 성립하지 않는 주장

#	한계	내용
1	계층 판정이 아직 미성립	서사의 핵심 문장인 "원인 계층을 패킷 근거로 짚는다"는 현재 성립하지 않는다. 계층별 프로브 0 건, node_exporter·cAdvisor 0 건, tcpdump 미사용이다. Toxiproxy 는 프록시 레벨이라 커널 큐 거동을 재현하지 않는다. 이 문장을 현재형으로 쓰면 계획서 자체가 반증된다. 발표 시점까지 실행되지 않으면 해당 주장을 슬라이드에서

		삭제한다
2	증명 ②의 대표 수치가 비어 있다	E4 RTO 미확인. 구 문서의 값은 T5 술어 교체 이전이라 인용 금지다. 현재 인용 가능한 RTO 는 E2·E5·E7 이며 이들은 kill 이 아니라 단절·분단·pause 실험이다. "리더를 죽여도"라는 서사와 제시 수치의 실험 종류가 다르다는 점을 발표에서 먼저 밝힌다
3	증거가 휘발성이다	카오스 볼륨은 `down -v` 로 파기되고 Write-Verdict 는 콘솔 JSON 만 낸다. 남는 증거는 문서 패치 노트와 커밋 본문뿐이다. 제출 전 파일 영속화 배선이 필요하다
4	"0 행 = 무결"과 "0 행 = 아무 일도 안 일어남"의 구분	부하가 실제로 걸린 상태에서 잰 0 행이어야 의미가 있는데 k6 실행 배선이 0 건이다. 현재 부하 원천은 봇 플릿뿐이고 체결 증분은 정량적 부하 프로파일이 아니다

13.2 물리·구조적 한계

#	한계	내용
5	물리 장비 없음	현재 전 구성이 단일 개발 머신의 Docker 컨테이너다. 클라우드 이관으로 노드 간 실제 ENI 트래픽까지는 가지만 물리 세그먼트 분리는 아니다
6	단일 AZ·단일 리전	NAT Gateway 와 AZ 간 전송료를 없애려고 한 AZ 에 몰았다. AZ 장애·리전 장애는 이 프로젝트의 복구 범위 밖이며 구성도에 명시한다

7	상시면이 단일 장애점이다	이 프로젝트 주제가 고가용성인데 상시 구동면은 HA 가 아니다. 학교 요건이 접속 가능성이고 HA 증명은 증명 창에서만 성립한다. 24 시간 HA 로 올리면 app-2 + pg-standby 상시 구동으로 월 약 63,770 원이 더 들어 상한을 56% 넘긴다. 답은 "비용 상한 안에서 24 시간 HA 를 유지할 수 없어 증명면을 창 구동으로 분리했다"이지 "HA 다"가 아니다
8	서비스 평면에서는 파괴 실험을 못 한다	평면 분리는 "실제로 사용자가 접속 중인 시스템에 장애를 주입했다"는 주장을 포기하는 대가로 성립한다. tc netem·nftables·커널 파라미터 실험은 전부 증명면 결과다. 이 구분을 발표에서 흐리지 않는다
9	AWS 실험은 로컬 실험의 부분집합	9 종 전량을 AWS 에서 반복 실행할 예산이 없다. "AWS 에서 9 종 전부 통과"는 이 예산으로 주장할 수 없다. AWS 에서 재현할 실험을 명시적으로 골라 적는다
10	시계 스큐 내성 미증명	Docker VM 시계의 비단조성이 과거 E5·E7 판정을 흔든 적이 있다. 시계 스큐 자체에 대한 내성은 검증 범위 밖이다

13.3 다중 노드 선행 조건 (미충족)

수평 확장은 주장하지 않는다. 현재 다중 인스턴스는 리더·팔로워 페일오버 구조로만 성립한다.

항목	상태
NonceStore	ConcurrentHashMap 기반 단일 노드 인메모리. 정본 계약은 Redis SET. 노드 간 공유가 없어 교차 노드

	재전송이 뚫린다
WebSocket	단일 노드 SimpleBroker. StompBrokerRelay 등 크로스노드 팬아웃 없음
잔고 사전 가드	in-flight 예약 누계가 게이트웨이 프로세스 인메모리. 다중 노드에서 성립하지 않는다

NonceStore 는 알려진 보안 결함이고 이번 6 주에 닫지 않는다. 닫으려 하면 다른 축과 충돌한다. nginx 가 `non_idempotent` 로 POST 를 재시도하는데 공유 nonce 저장소가 생기면 그 재시도가 등록된 nonce 를 재생해 401 이 되어 가용성 지표가 나빠진다. 또 E3 의 SKIP 유효 판정 근거가 "Redisson 미배선"이므로 Redis 를 넣으면 그 판정 근거가 무효가 된다. 보안 개선 하나가 HA 판정 설계와 부하 오류율 예산을 동시에 건드린다. 선택은 "닫지 않고 한계로 명시"로 고정한다.

RPO=0 은 단일 PostgreSQL 인스턴스 범위에서만 성립한다. failover 를 포함한 무손실은 동기 standby, synchronous_commit, 클러스터 STONITH 운영 요건을 전제하며 그 전제는 충족돼 있지 않다. W6 에 standby 동기화와 수동 승격까지는 도달 가능하다고 보지만 자동 승격은 미완으로 남을 확률이 실질적이다.

13.4 실행 리스크

#	리스크	완화
11	Rocky Linux 10 AMI 의 AWS 가용성과 SSM Agent 호환을 실측하지 않았다	W1 최우선 확인 항목. 공식 AMI 가 없거나 SSM Agent 가 RHEL 10 계열에서 문제를 내면 SSH 폐쇄 계획이 흔들린다
12	Docker 와 nftables 의 마찰	RHEL 10 에 iptables 가 없다. Docker Engine 의 nftables 지원 성숙도를 실측하지 않았다. 최악의 경우 podman 전환인데 그러면 카오스 스크립트 9 종이 깨진다. 완화책은 방화벽 작업을 호스트 인그레스 경계와 포트 노출 축소로 한정하는 것이다. 1 주차에 이 판정을 먼저 한다
13	권한 분리 전환이 회귀를 낸다. 규모를 모른다	통합테스트 33 클래스가 슈퍼유저로 돌아 이 결함군을 구조적으로 못

		잡는다. 전환 후에야 목록이 나온다. 완화책은 프로파일 스위치로 즉시 롤백 가능하게 하고, 최소 1 개 클래스를 앱 롤 접속으로 돌리는 회귀 러너를 함께 만드는 것이다
14	tc netem 이 자기 발등을 찍을 수 있다	클라우드 노드에 네트워크 장애를 주입하면 SSM 접근 경로도 같은 네트워크를 탄다. 회복 불가 시 콘솔 강제 재기동뿐이고 그 사이 실험 데이터가 유실된다. 완화는 평면 분리와 EBS 스냅샷 사전 확보이지만 노드를 잃는 사건 자체를 막지는 못한다
15	가용 시간 가정이 검증되지 않았다	수업일 6h 가 5h 로 내려가면 순 가용이 336h 에서 약 282h 로 줄어 예비 60h 를 전부 태워도 모자란다. 09-04 특별 판정을 넣은 이유다
16	예비 60h 가 과거 마찰 규모에 미달한다	판정 경로 추적 전례 7 건이 각각 2~3 일, 합하면 100h 를 넘는다. 예비가 성립하는 조건은 동시에 2 건 이상 터지지 않고 시한 규칙(환경 4h, 판정 8h)을 실제로 지켜 조기 중단하는 것이다. 조기 중단을 지키지 못하는 것이 가장 흔한 실패 모드다
17	W6 가 3 일뿐이다	클라우드 스택에서 전 실험을 돌려본 적이 한 번도 없는 상태로 최종 완주에 진입한다. 실패하면 예비 5h 로 흡수가 안 되고, 발표 준비 주간을 침범하지 않기로 했으므로 실제로는 실험 일부를 미완주로 남기고 한계로 발표하는 결말이 된다
18	계획에 잡히지 않은 소요	도메인 DNS 전파 지연, AWS 계정

		검증·쿼터, 추석 연휴 가족 일정, AWS SAA 학습 시간 0h 배정
19	버전 스큐가 롤백에서 드러난다	웹은 빌드 타임에 계약을 인라인한 정적 산출물이고 앱은 컨테이너 이미지라 롤백 단위가 다르다. 웹·앱 태그를 커밋 SHA 로 묶어 동시 롤백하는 규약이 필요하며 아직 설계만 있고 스크립트가 없다
20	CloudFront 가 관측을 한 겹 흐린다	사용자가 보는 경로는 CF 를 지난 경로이고 판정은 오리진 직접 측정이다. 두 수치를 대시보드에서 분리 표기하지 않으면 뒤섞인다

13.5 비용 축의 미확정 값

#	항목	상태
21	인터넷 아웃바운드 20GB/월	추정. WebSocket 6 채널 지속 송출이 유일한 폭주 경로이고 상한을 관측 전에는 못 잡는다. 배포 첫 주에 실측으로 갱신
22	Micrometer 시계열 500 종	추정. CloudWatch 대안 비용의 절반 이상이 이 가정 위에 있다. `/actuator/prometheus` 계수로 확정
23	증명면 가동 65 시간	추정. AWS 에서 실험을 한 번도 돌린 적이 없어 회차당 소요를 모른다
24	arm64 이미지 실물 확인	미검증. 하나라도 없으면 x86 폴백이고 상시면이 월 USD 9.49 오른다
25	크레딧 적용 범위	계정 개설 전에는 확인 불가. 산정은 크레딧 0 으로 잡았다
26	단가 스냅샷	2026-08-24 판. AWS 는 요금을 바꾼다

27	환율	1,500 원 구간에서 여유가 1%로 줄어든다. 2026 년 7~8 월 실환율이 1,406~1,494 원 구간이었으므로 가상의 시나리오가 아니다
28	사고 비용은 산정에 없다	켜 둔 채 잊은 노드, 지우지 못한 스냅샷, 유출 키로 인한 채굴 과금. 특히 저장소 이름과 주제에 암호화폐 문자열이 들어가 자동 스캐너의 표적이 되기 쉽다. 장기 액세스 키 미발급이 가장 확실한 방어다

13.6 개발 환경 한계

항목	상태
한글 경로	현재 저장소 물리 경로에서 `gradlew test` 가 ClassNotFoundException 으로 실패한다. 3 조합 중 PowerShell + 정션 `C:\dev\exchange` 1 조합만 통과한다. W0 에 Rocky VM 이설로 이 계열 결함을 구조적으로 제거한다
문서 경로 오류	문서 7 개 파일 24 행이 드라이브 문자를 박아 두어 PC 가 바뀌면 전부 틀린 경로가 됐다. `$env:EXCHANGE_HOME` 환경변수로 분리해 **해소**(커밋 d9f07f6)
통합테스트 Docker 의존	33 클래스가 각자 PostgreSQLContainer 를 선언하고 공유 베이스도 재사용 설정도 없다. Docker 가 없으면 해당 202 개 테스트 메서드가 실패한다
미커밋 산출물	`.codex/`, 라이브데모 대본이 git 미추적이다. 산출물로 주장하려면 원격에 있어야 한다. W0 에 커밋

13.7 안 하는 것

이름으로 적는다.

- API 키 발급·회전·폐기 3 종. 관리 평면 3 종(봇 제거·시나리오 프리셋·텔레메트리 WS).

- 침투 테스트, 퍼징, OWASP Top 10 전수 점검, STRIDE 위협 모델 문서, WAF, RLS, 마스터키 회전.
- Kubernetes·ECS 등 오케스트레이터 도입.
- 수평 확장(전 노드가 동등하게 쓰기를 받는 구조).
- 다중 AZ·다중 리전 복구.
- 자동 DB 승격(Patroni·repmgr·STONITH). 예비 잔량 조건 충족 시에만 스트레치로 착수.
- 모바일 앱과 반응형 웹. 고정형 데스크톱 전용 웹이며 최소 폭 1280px 다.